

Version 2.3 — Reconciled Methodology

This is the current, authoritative version of the DeFiJerusalem scoring methodology, as of June 2026. If this document is uploaded to a new conversation, it should be treated as the complete and final reference — every number, weight, and rule in this PDF reflects actual reconciliation work, not a draft or proposal.

Version Lineage

Version	Status	What It Was
v1.0 / v2.0	Superseded	Initial methodology; 50/50 Foundation/Active split, later corrected
v2.1	Superseded by this document	First fully-specified version: 45/55 split, complete Foundation/Active sub-components, original 8 category tables, 2 universal checks (Inherited Risk, Concentrated Control Risk), -25 penalty ceiling. Used throughout most of this project's scoring work.
v2.2	Never shipped — historical reference only	A research-stage proposal (not a built version) covering 4 identified gaps: flash loan resistance, key management, governance attack resistance, audit/bounty scope. Designed but never implemented as a live scoring system.
v2.3 (this document)	Current, live	v2.1 with every open question from the v2.2 research resolved, plus real errors found and fixed during reconciliation. Not a new proposal — a closure of v2.1's own loose ends.

What Changed From v2.1 to v2.3 — Complete List

Change	Detail
Audit/Code split corrected	Audit & Verification: 20 → 18 points. Code & Contract History: 10 → 12 points. Foundation's total remains 45. Adopts the methodology's own research recommendation (audits show weak protection against novel attacks; current code state deserves more weight).
Universal Checks expanded: 2 → 3	Added Supply Chain Risk (-5 ceiling), validated by two real cases (Trust Wallet \$7M, Polymarket \$3.1M). Tested for universality and passed across all 8 categories — unlike a flash-loan-resistance candidate that was tested and rejected for the same reason. Penalty ceiling: -25 → -30.
New watch-item: Audit/Bounty Scope Coverage	Added to Universal Penalty Checks, -2 ceiling, SIMILAR MATCH only. Validated by Cork Protocol (\$12M), Abracadabra, and GMX V1 (\$42M).

Change	Detail
Lending Pattern 3 promoted	Curator/Allocator Risk moved from watch-item to full pattern. Validated by Stream Finance (~\$285M) and the Resolv USR exploit (15+ Morpho vaults). Lending category rebalanced: P1 -7, P2 -4.5, P3 -3.5 = -15.
Derivatives Pattern 2 promoted	Oracle/Mark Price Latency moved from watch-item to full pattern. Validated by KiloEx (\$7.4M) and the October 2025 market-wide liquidation cascade (\$19.3B). Derivatives core rebalanced: P1 -10, P2 -5 = -15; P3 remains a separate watch-item.
DEX/AMM Pattern 1 citation corrected	Cetus Protocol (\$223M) removed as a validating case — its actual root cause (an arithmetic overflow-check bug) does not match Pattern 1's mechanism (spot-price manipulation). Reclassified as a Universal Core / code-logic case, the same boundary as Euler. Pattern 1 now validated by KiloEx and PancakeSwap only.
Move-chain translation note added	Lending Pattern 2 now documents that Move's resource model structurally resists donation/balance-inflation attacks, while flagging that this does not replace auditing (confirmed by the Typus oracle exploit on Sui Move).

Current Open Items (Not Yet Resolved)

Supply Chain Risk and Audit/Bounty Scope Coverage were added after several protocols were already scored. Aave, Uniswap, the Frax ecosystem, and the Lido ecosystem do not have these two lines applied to their existing scores. They are not wrong under the version they were scored against, but are not yet re-evaluated under v2.3's complete check set.

Supply Chain Risk (third-party library/dependency vulnerabilities, distinct from the frontend/release-pipeline mechanism above) remains a logged, unscored gap. No pattern in this methodology currently checks dependency/library security specifically.

Insurance Pattern 3 (Voter Apathy) and Derivatives Pattern 3 (Binary Settlement Risk) remain watch-items, each resting on a single validating case. Both were actively re-researched for a second case during this project and not found — they remain honestly capped, not neglected.

How to Use This Document

The pages that follow are the complete methodology, in reading order: the scoring formula and multi-product rule, the full Foundation/Active gross-score specification, the empirical research basis, the Universal Penalty Checks (all three), all eight category-specific penalty tables, and the Scoring Procedure document (the eight-step process, calibration table, and every gate built from a real, caught mistake). Read top to bottom for the full methodology, or jump to any single category table as a standalone reference — each is self-contained.

DeFiJerusalem Scoring Methodology

Internal reference. Not yet public — scheduled for release alongside the DeFiJerusalem platform launch. This document compiles the complete scoring system: the formula, all eight category-specific penalty tables, the two universal checks, and the procedural rules built to keep results reproducible regardless of who performs the scoring.

The Formula

$$\text{FINAL SCORE} = \text{Gross Score} - \text{Category Penalty} - \text{Inherited Risk} - \text{Concentrated Control Risk} - \text{Supply Chain Risk}$$

Gross Score = Foundation (0–45) + Active (0–55), capped at 97. Category Penalty is drawn from exactly one of the eight category-specific tables in this document (0 to -15 ceiling, occasionally split into a core total plus a separate, lower-confidence watch-item ceiling). Inherited Risk, Concentrated Control Risk, and Supply Chain Risk are universal — applied regardless of category, each capped at 0 to -5. Combined penalty ceiling: **-30** (expanded from -25 after Supply Chain Risk was confirmed to apply across all eight categories — see the Scoring Procedure document's reconciliation). The floor of any final score is 0; the ceiling is 97.

Match-Status Rule (Applies Identically in Every Category Table)

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction for that pattern
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger (more conservative) deduction.
NOT PRESENT	0 — checked, pattern not found
NOT APPLICABLE	0 — pattern does not apply to this product's design at all, distinct from NOT PRESENT
CANNOT DETERMINE	0 — disclosed separately as “unverified,” never silently treated as NOT PRESENT

Reconciliation With v2.1's Systemic Penalties

v2.1 (the last fully specified prior version of this methodology) included a separate, flat Systemic Penalties section: Oracle Dependency Risk (-5 to -7), Centralization Risk (-3 to -5), Bridge/Cross-Chain Risk (-2 to -5), and Supply Chain Risk (-3), capped at -18 total. This section reconciles that structure against the category-table system in this document, built independently afterward.

Three of v2.1's four categories are retired as redundant, not merged: Oracle Dependency Risk is fully subsumed by DEX/AMM Pattern 1, RWA Pattern 2, and the Derivatives oracle-latency watch-item — each more granular and each tied to a named, dated incident, where v2.1's version had none. Centralization Risk is subsumed by Concentrated Control Risk, which has three independent validating cases (Solend, Frax, Hyperliquid) v2.1's version never had. Bridge/Cross-Chain Risk is subsumed by the five-pattern Bridge category table, validated against 6+ real incidents, far exceeding v2.1's single flat line. These three are not kept at reduced weight — they are fully replaced.

Supply Chain Risk (-3, vulnerable third-party dependencies) is the one genuine gap this reconciliation found. No pattern in this methodology currently checks a protocol's dependency/library security specifically. It is not added to the -25 ceiling here — doing so would require either exceeding the agreed ceiling or displacing an already-validated pattern, and it has zero validating incidents behind it, the same bar every other pattern was required to clear before being trusted. It is logged as an **unscored, open watch-item**: flagged in any output where dependency risk is visibly relevant, but assigned no points, pending a real incident or a deliberate decision to make room for it in the ceiling.

Net result: the -25 ceiling is unchanged. This reconciliation confirms the category-table system already contains everything of substance from v2.1's Systemic Penalties, at greater precision, with one honestly logged gap rather than a silently dropped one.

Note: the -25 figure above reflects the state of this reconciliation at the time it was performed. The ceiling was later deliberately expanded to -30 after Supply Chain Risk — the gap flagged here — was independently validated by two real incidents and confirmed to apply across all eight categories. See the Scoring Procedure document for that later reconciliation; the Supply Chain Risk gap described above is no longer open.

Multi-Product Rule

A protocol spanning more than one materially distinct product (different TVL, different function, different contracts) is scored once per product, never blended into a single number. Each product gets its own Gross Score, its own category penalty, and its own Concentrated Control Risk weighting scaled to whether shared governance has demonstrated authority over that specific product (full weight) or only general, ecosystem-wide authority (half weight). An ecosystem-level average may be presented alongside the individual scores, but never in place of them.

Document Contents, In Reading Order

Section	Covers
Universal Penalty Checks	Inherited Risk, Concentrated Control Risk, and Supply Chain Risk — the three checks applied to every protocol regardless of category
Lending	Collateral concentration, exotic token integration, curator/allocator risk (watch-item)
DEX/AMM	Spot-price manipulation, pool ratio distortion

Section	Covers
Bridge	Verifier independence, failover behavior, key custody, signing-interface spoofing
Derivatives	Leverage/liquidity mismatch (core), oracle latency and binary settlement risk (watch-items)
Stablecoin	Mint authority control, collateral liquidity depth, off-chain operational dependency (watch-item)
Yield Aggregator	Deprecated strategy retirement, donation-manipulable share price
RWA	Off-chain custody/operational key risk, oracle/proof-of-reserves integrity
Insurance	Capital pool adequacy, correlated claims-assessor conflict, voter apathy (watch-item)
Scoring Procedure	The eight-step process and verification gates used to keep every score reproducible — includes the live calibration reference table

Liquid Staking/Restaking has no standalone category table — its risks decompose into Lending (collateral/counterparty concentration) and the Inherited Risk universal check, per the established rule. Protocols scored so far under this methodology: Aave, Uniswap, the five-product Frax ecosystem, and the three-product Lido ecosystem.

Gross Score Methodology: Foundation + Active (v2.1)

This is the actual, complete v2.1 specification for computing the 0–97 Gross Score (before any category penalty or universal check is applied). This was previously summarized as a single line (“Foundation 0–45 + Active 0–55”) in the overview document without the underlying formulas — this document is the missing detail layer, and is what was actually used to compute every protocol score in this project.

Changelog: Audit & Verification reduced from 20 to 18 points, Code & Contract History increased from 10 to 12 points — adopting the research basis document's own recommendation (Landsman et al., SSRN 2025: audits show little evidence of preventing future breaches once exploited; Halborn data on heavily-audited protocols still being exploited via sophisticated attacks audits don't catch). This decision was deferred when first identified and is now resolved; the change shifts weight toward the current, verifiable state of deployed code rather than historical audit paperwork. Foundation's total remains 45.

Structure at a Glance

Component	Max Points
FOUNDATION (what they built)	45
Audit & Verification	18
Code & Contract History	12
Track Record	10
Documentation	3
Historical Governance	2
ACTIVE (how they protect now)	55
Security Infrastructure	22
Incident Response	15
Proactive Monitoring	7
Economic Health	6
Live Governance	3
Ongoing Vigilance (chain-level, distinct from A2b below)	2
BASE SCORE (Foundation + Active)	100
Predictive Bonus (new protocols <6mo only)	0–3
GROSS TOTAL (before ceiling)	0–103

Component	Max Points
SCORE CEILING (applied before any penalty)	97

Critical sequencing rule: the 97-point ceiling is applied to the Gross Total before any category penalty or universal check is subtracted — never after. A protocol scoring 95.4 gross with a -3 penalty lands at 92.4, not at $\min(95.4-3, 97)$.

FOUNDATION (45 points)

Foundation measures historical security investment — less predictive of future failure than Active, but establishes baseline credibility.

F1. Audit & Verification — 18 points

Tier	Example Firms	Base Points
Tier 1	Trail of Bits, OpenZeppelin, Consensys Diligence	22
Tier 2	Quantstamp, PeckShield, Hacken, SlowMist	16
Tier 3	CertiK, SolidProof, TechRate	12
No audit / unrecognized	—	3

Base points are then multiplied by a decay factor reflecting the audit's age, capped at a minimum of 0.50x, then capped at a maximum of 18 (the 22-point Tier 1 base can exceed 18 only before decay — the final score after any decay is always capped at 18):

```
decay_multiplier = max(0.50, 1.0 - (age_months / 48))
```

Audit Age	Decay Multiplier
0 months	1.00x (full value)
12 months	0.75x
24 months	0.50x (floor reached)
36+ months	0.50x (capped at floor)

If the most recent audit has unresolved critical findings, the decay multiplier is further multiplied by 0.5 (a 50% additional penalty). Formula: $\text{final} = \min(18, \text{base_points} \times \text{decay} \times \text{critical_penalty})$. Worked example: a Tier 1 audit (22 base) at 12 months old (0.75x decay), no unresolved criticals $\rightarrow 22 \times 0.75 = 16.5$, under the 18 cap so no further reduction applies.

F2. Code & Contract History — 12 points

Component	Points	Verification Method
Source code verified	6	Block explorer API verification

Component	Points	Verification Method
Clean vulnerability scan	6	Static analysis (Slither/Mythril/Echidna) shows zero critical or high findings

F3. Track Record — 10 points

Combines protocol age (survival bias) with exploit history. Age contributes up to 8 points (48+ months of operation = full 8 points, scaled down for younger protocols); exploit history then applies a modifier: +2 points if the protocol's own contracts have never been exploited, scaling down to as low as -10 points for a severe, unresolved exploit history. The combined score is floored at 0 and capped at 10.

F4. Documentation — 3 points | F5. Historical Governance — 2 points

Component	Points
Technical documentation (comprehensive)	1.5
Admin controls documented	1.5
On-chain DAO established	1.5
Timelock mechanism present	0.5

ACTIVE (55 points)

Active measures current operational security — the most predictive component, weighted higher than Foundation because access-control failures alone caused 59–83% of DeFi losses in 2025 data.

A1. Security Infrastructure — 22 points

A1a. Access Controls — 12 points (critical rule: <50% threshold always scores 0)

Configuration	Threshold	Points
DAO governance / Immutable (no admin)	N/A	12
Timelock + Multisig	≥71%	12
Multisig (no timelock)	≥71%	8
Multisig	60–70%	5
Multisig	50–59%	3
Multisig	<50%	0 — FAIL, no exceptions
EOA admin (single wallet)	N/A	0

This rule exists specifically because the original v1.0/v2.0 methodology gave identical credit to a 3-of-5 (60%) and a 3-of-11 (27.3%) multisig — the exact configuration later exploited at Radiant Capital for \$53M. v2.1 was revised specifically to make this distinction after that incident.

A1b. Oracle Security — 6 points | A1c. Emergency Response — 4 points

Configuration	Points
Multiple independent oracle sources	6
Single oracle (even if Chainlink)	3
Custom/unaudited oracle, no redundancy	0
Circuit breaker / pause mechanism	2
Emergency withdrawal path for users	2

A2. Incident Response — 15 points

A2a. Bug Bounty (11 pts): requires API-verified program (Immunefi/HackerOne), hybrid scoring combining absolute dollar value and percentage of TVL, and a recent verified payout (within 90 days) for full credit. A2b. Ongoing Vigilance (4 pts): 1 point each for monitoring alerts in the last 30 days, security updates in the last 30 days, a bug bounty payout in the last 90 days, and active community engagement.

A3. Proactive Monitoring — 7 points

Static Analysis (4 pts): automated scanning tools actively run against the protocol's code. Real-Time Monitoring (3 pts): live on-chain monitoring confirmed via 3+ platforms (Forta, OpenZeppelin Defender, CertiK Skynet, Tenderly) scores full; 1–2 platforms scores partial; none detected scores 0.

A4. Economic Health — 6 points | A5. Live Governance — 3 points

Component	Points
TVL stability	2
Revenue generation	2
User retention	1
Liquidity health	1
Active governance operations	1
Transparency	1
Execution speed	1

Predictive Bonus — 0 to 3 points (new protocols only)

Applies only to protocols under 6 months old; expires automatically at 6 months. +1 for formal verification (Certora/Runtime Verification report), +1 for a clean Tier 1 audit, +1 for a bug bounty worth at least 2% of TVL. This is the only mechanism by which the Base Score (max 100) can exceed 100 before the 97 ceiling is applied.

Source Discrepancy Found During Verification — Flagged, Not Silently Resolved

Per this project's own Step 5 (independent arithmetic verification), the five named Active sub-components in the primary v2.1 source documents (Security Infrastructure 22 + Incident Response 15 + Proactive Monitoring 7 + Economic Health 6 + Live Governance 3) sum to 53, not the documented 55-point Active total — a 2-point gap in the source material itself, not introduced by this project. A separate source document (COPY_THIS_COMPLETE_ANALYSIS.txt) lists an additional "Ongoing Vigilance: 2 pts" line under an earlier v2.0 Active breakdown that does not appear as its own named line in the primary v2.1 tables — it is included above as the most likely explanation for the missing 2 points, restoring the total to 55, but this is a reasoned reconciliation of conflicting source material, not a confirmed fact. This should be verified against the original methodology's intent before being treated as settled.

Open Item From This Project's Scoring Work

Every score computed in this project so far (Aave, Uniswap, the Frax and Lido products) used holistic, evidence-based judgment for each sub-component rather than the literal automated detection logic above (e.g., parsing an exact multisig string, querying a monitoring API directly). This is appropriate given this project's research is manual and source-based, not automated — but it means scores in this project are a reasoned approximation of this formula, not its mechanical execution. Re-deriving Aave's score against this exact document (done as the first test case) moved the final score by only 0.5 points, suggesting the approximation is sound, but this distinction should be stated wherever a score from this project is presented as methodology-derived.

Research Basis: The Empirical Study Behind v2.1

Every weight in the v2.1 Gross Score formula traces back to an empirical analysis of 500+ real DeFi exploits (2020–2025, \$14B+ in tracked losses), cross-referenced against named industry and academic sources. This document is that research, in full — what was validated as-is, what was identified as needing refinement, and what gaps were found but never closed.

Data Sources

Source	Contribution
Rekt News Leaderboard	273 major exploits, 2020–2025
Immunefi Annual Reports	2020–2025 (partial), bounty/payout data
Halborn Top 100 DeFi Hacks	Comprehensive analysis, 2016–2023
Cicada Partners DeFi Risk Analysis	October 2025
CoinLaw Smart Contract Security Statistics	2025
Landsman et al. (SSRN, April 2025)	Academic study on audit effectiveness
CertiK Oracle Wars Analysis	2025
Hacken Q1 2025 Security Report	—
Chainalysis Mid-Year 2025 Report	—
DeFiYield REKT Database	Historical, 2020–2021

Total: 500+ exploits analyzed, \$14B+ in tracked losses, 2016–2025 (focus on 2020–2025).

Annual Loss Trends — The Backdrop

Year	Total Losses	Incidents	Avg/Incident
2020	~\$500M	95	\$5.3M
2021	\$1.7B	120	\$14.2M
2022	\$3.9B (peak)	134	\$29.1M
2023	\$1.8B	320	\$5.6M
2024	\$1.49B	232	\$6.4M
2025 (H1)	\$2.0B	154	\$13.0M

Incident count has trended down since the 2022 peak, but average exploit size is rising again in 2025 — read as sophisticated attackers increasingly targeting larger protocols rather than the ecosystem becoming categorically safer.

Validated As-Is

Finding	Evidence
45/55 Foundation/Active split	Supported across 2020–2025 data; year-by-year analysis suggested the ideal split shifted from ~50/50 (2020–21) toward 35/65 (2024–25) as operational failures grew, but 45/55 was kept as a conservative, defensible middle ground for 2025 launch.
Audit decay function (100%→75%→50%→25%)	Balancer (\$128M, Nov 2025): last full audit of the exploited logic was 2021/2022, flagged at the time as “undetermined severity” and proven exploitable 4 years later. Abracadabra (\$1.8M, Oct 2025): foundational CauldronV4 logic last audited Nov 2023, ~2 years before exploit, while newer features kept getting reviewed and the old foundation “sat untouched.” Both cases land exactly where the decay curve predicts.
Access control emphasis (11–12 pts)	65% of 2025 exploits attributed to access control failures; Immunefi reported \$1.6B in 2025 losses from this category alone.
Oracle security weighting (5–6 pts)	13–22% of exploits across sources (CoinLaw: 13% in 2025) — real but smaller than access control, justifying a lighter weight.
Bug bounty scoring (\$1M+ tier)	LayerZero: \$15M bounty, zero exploits to date. Cork Protocol: \$100K bounty vs. a \$12M exploit — 120x more profitable to attack than to disclose. The Immunefi CEO's own stated standard (“roughly 10% of funds at risk”) informed the tiering.

The Audit Paradox — Why Audit Weight Was Flagged for Reduction

From Halborn's Top 100 DeFi Hacks (2016–2023): audited protocols accounted for only 20% of hacks and 14.3% of total losses, versus 80% of hacks and 85.7% of losses for unaudited protocols — a real, large effect. But a separate academic study (Landsman et al., SSRN, April 2025) found little evidence that audits reduce *future* security breaches once a protocol has already been breached once; protocols mainly just switch auditors afterward. Multiple heavily-audited protocols (Balancer: OpenZeppelin, Trail of Bits, Certora, ABDK — over a dozen reports; Euler Finance, \$197M, March 2023) were exploited despite extensive audit histories, particularly via sophisticated multi-vector attacks audits aren't well-suited to catch. This tension — audits clearly help on average, but provide much weaker protection than their cost might suggest, especially against novel attack classes — is why the original analysis recommended trimming audit weight from 20 to 18 points and shifting the difference to Code & Contract History.

Status: applied. This recommendation was deferred when first identified during this project's reconciliation work, then formally adopted — see the Gross Score Methodology document's changelog. Audit & Verification is now 18 points, Code & Contract History is 12 points. Every score computed in this project before this decision (Aave, Uniswap, all Frax and Lido products) used the prior 20/10 split and has not been retroactively recalculated; the 0.5-point shift observed when Aave was independently re-derived earlier suggests any such recalculation would move scores only marginally, but this has not been confirmed for every protocol.

Real Gaps Identified — Never Closed (v2.2 Never Shipped)

Four real, evidenced gaps were identified during this research. All four were assigned to v2.2, which was designed but never built (confirmed earlier in this project). They remain open gaps in the methodology actually used throughout this project's scoring work.

Gap	Evidence	Planned Fix (Never Shipped)
Flash loan resistance — not scored at all	24–32% of all exploits use flash loans; Halborn found 83% of “eligible” exploits in 2024 used this vector; \$403.2M stolen across 41 historical flash loan attacks.	Economic Attack Resistance, +3 pts (v2.2)
Private key security — underweighted	Grew from 0% of exploits (2020) to 25% (2025), the fastest-growing vector. DMM Bitcoin (\$305M), WazirX (\$235M), Radiant Capital (\$50M, malware-laced PDF to engineers) — all 2024. Halborn: only 21.1% of protocols used multisig/MPC wallets; only 5.3% used cold storage for critical keys.	Key Management, +2 pts, carved out of existing Security Infrastructure (v2.2)
Governance attack resistance — not scored	Beanstalk (\$181M, 2022): flash-loan-funded governance takeover. Multiple smaller 2023–24 repeats of the same pattern.	Governance Attack Resistance, +2 pts (v2.2)
Audit scope coverage — not penalized	Cork Protocol (\$12M): exploited contracts were reportedly out of bounty/audit scope. Abracadabra: deprecated contracts left unaudited while new features kept getting reviewed. GMX V1 (\$42M): legacy contracts possibly excluded from bounty scope.	Audit/bounty scope-gap penalty, -2 to -3 pts (v2.2)

Cross-reference to this project's own pattern-checker work: the Audit Scope Coverage gap above is conceptually close to the “Audit Scope Coverage Risk” penalty category already built into the original (pre-reconciliation) Systemic Penalties table, and is distinct from “Supply Chain Risk” (third-party dependency vulnerabilities), which remains a genuinely separate, still-open gap per this project's reconciliation work.

MEV/Front-Running Protection — Identified, Status Unclear

Flagged as unscored in the original research, planned for v2.2 (+2 pts). Never resolved in this project's work either — no pattern in the eight category tables checks for MEV exposure specifically.

Exploit Prevention Estimate — Revised Down Honestly

The original, pre-research marketing claim was 40–50% of exploits preventable, \$5.8–\$7.2B in annual prevented losses. After the empirical analysis, this was revised down: realistic estimate 60–70% of exploits theoretically preventable with high scores (a higher percentage than the original claim, but conditioned on full, idealized adoption), translating to a more conservative \$1.75–\$2.1B in realistic annual prevention once accounting for partial adoption and protocols ignoring warnings. The research explicitly states what cannot be prevented: private key compromises via social engineering (~18–20% of all exploits), and novel zero-day attacks (~5%) such as the Curve Vyper compiler bug.

Honest Summary

This methodology has a genuine empirical research base — not a post-hoc justification for arbitrary numbers. Five of its core weighting decisions are directly evidenced by named, dated incidents and named industry/academic sources. At the same time, the research itself identified five real refinements and gaps (audit weight, private keys, flash loans, governance attacks, scope penalties) that were never implemented, because v2.2 — the version meant to carry them — was designed but never built. Anyone presenting this methodology externally should be able to cite this research base confidently, while also being able to name its known, currently-unaddressed gaps just as plainly.

Pattern Derivation Research — v2.1 to v2.3

This document consolidates the real, dated research behind every pattern promotion, correction, and new check added during the v2.3 reconciliation. It is distinct from *02_Research_Basis_v2.1.pdf*, which covers the original empirical study (500+ exploits, 2020–2025) behind the Gross Score formula itself. This document covers the category-table and universal-check level work — each pattern's actual evidence, found and verified during this reconciliation, not assumed.

1. New Universal Check: Supply Chain Risk

Question asked: does a real, validated mechanism exist for a protocol's frontend, browser extension, or release pipeline being compromised through a third-party dependency or vendor relationship, distinct from a smart contract bug?

Case	Date	Finding
Trust Wallet Chrome Extension	Dec 2025	A leaked Chrome Web Store API key let an external party publish a malicious extension version, bypassing the internal manual release process entirely. \$7M confirmed loss; users refunded.
Polymarket Frontend	June 2026	A compromised third-party vendor injected malicious JavaScript into the platform's website, draining 11 confirmed wallets. \$3.1M confirmed loss — the platform's second serious failure in five weeks.

Universality test (the deciding factor): checked against all eight categories, including Bridge and RWA — the two that disqualified a separate flash-loan-resistance candidate (see Section 6). Every category has some user-facing frontend or release pipeline; the mechanism passed. Result: built as a third universal check, -5 ceiling. Ceiling moved from -25 to -30, deliberately.

2. New Watch-Item: Audit/Bounty Scope Coverage

Question asked: does a real mechanism exist for a protocol's actually-deployed contracts falling outside its own claimed audit or bounty scope?

Case	Finding
Cork Protocol (\$12M)	Exploited contracts were reportedly out of the protocol's own bounty scope.
Abracadabra	Deprecated CauldronV4 logic left unaudited for roughly two years while newer features kept getting reviewed.
GMX V1 (\$42M)	Legacy contracts possibly excluded from the bounty program's scope.

Built as a watch-item (-2 ceiling, SIMILAR MATCH only — inherently a binary disclosure-gap question, not a severity tier), added to Universal Penalty Checks.

3. Lending Pattern 3 Promoted: Curator/Allocator Risk

Previously capped at SIMILAR MATCH (watch-item), pending a second real validating case beyond the original mechanism description.

Case	Date	Finding
Stream Finance xUSD collapse	Nov 2025	Curators (TelosC, MEV Capital, Re7 Labs, others) allocated depositor funds into markets accepting xUSD, chasing yield despite public warnings days before collapse. ~\$285M ecosystem exposure when xUSD depegged from \$1 to \$0.33.
Resolv USR exploit	March 2026	15+ Morpho vaults (Gauntlet, Re7 Labs, kpk, 9summits) had allocated into markets accepting USR as collateral; multiple curators opened after-the-fact compensation pools once USR was exploited.

Two independent cases, different root causes (yield-chasing into a depegging asset vs. allocation into a later-exploited market), same underlying mechanism: a curator's allocation decision, not Morpho Blue's own contract code, causing depositor loss. Promoted to full pattern. Lending rebalanced: P1 -7, P2 -4.5, P3 -3.5 = -15.

4. Derivatives Pattern 2 Promoted: Oracle/Mark Price Latency

Case	Date	Finding
KiloEx	April 2025	A price oracle issue let an attacker create a leveraged position exploiting the flawed feed, draining funds across Base, opBNB, and BSC. \$7.4M confirmed.
Market-wide liquidation cascade	Oct 2025	Oracle manipulation allowed a \$60M sell-off of USDe to trigger cascading liquidations market-wide, exploiting pricing tied to a manipulable spot source. \$19.3B in liquidations — broader than a single protocol, but the same root mechanism at systemic scale.

Promoted to full pattern. Derivatives core rebalanced: P1 -10, P2 -5 = -15. P3 (Binary Settlement Risk) remains a separate watch-item — not re-searched this round.

5. Searched, Not Promoted: Insurance Pattern 3 (Voter Apathy)

Two separate, targeted searches run specifically to find a second validating case beyond Neptune Mutual. Both returned only generic industry commentary on the conflict-of-interest mechanism (voters may act in their own self-interest) and one near-miss that actually evidences a different pattern (a Nexus Mutual case of a claimant voting for their own false claim — motivated self-interest, not apathetic herding). No second case found. Pattern correctly remains at watch-item status, SIMILAR MATCH ceiling — this is a real, attempted, and unsuccessful search, not neglect.

6. Retired: Flash Loan / Economic Attack Resistance

Originally a v2.2 proposal (+3 pts). Tested for universality the same way Supply Chain Risk was tested, and failed: flash loans have no real mechanism against Bridge (a same-block, single-chain loan cannot fund a cross-chain verification exploit) or RWA (an on-chain instrument cannot affect off-chain custody). Where the mechanism is real (DEX/AMM, Lending, Yield Aggregator), it was already fully priced into existing patterns (KiloEx for DEX/AMM P1; Cream Finance for Lending P2 and Yield Aggregator P2). Retired as redundant; explicit cross-reference notes added to all three affected patterns instead.

7. Corrected: DEX/AMM Pattern 1's Cetus Mis-Citation

Cetus Protocol (\$223M, May 2025, Sui) had been cited as a Pattern 1 (Spot-Price-Only Pricing) validating case throughout this project. Checking SlowMist's published root-cause analysis found the actual mechanism was an arithmetic overflow-check failure in a function called `checked_shlw`, which let an attacker mint massive liquidity for a near-zero deposit — the attacker never manipulated a price feed or read a manipulable reserve. This is the same category of flaw as Osmosis's JoinPoolNoSwap bug and Euler's missing health check, both already correctly excluded from this file as Universal Core / code-logic cases. A pattern check run against pre-exploit Cetus using Pattern 1's actual criteria would plausibly have returned NOT PRESENT or SIMILAR MATCH at best — missing the real vulnerability. Removed as a Pattern 1 case; reclassified into “What this file does NOT cover.” Pattern 1 now validated by KiloEx and PancakeSwap only.

8. Move-Chain Translation Note (Lending Pattern 2)

Following the Aave/Aptos dry run (Section 9), researched whether Move's resource model (used by Sui, Aptos) structurally affects Pattern 2's donation/balance-inflation mechanism. Found real, independent confirmation: Move's linear resource type prevents collateral from existing in two places at once by construction, explicitly cited in industry sources as the reason Euler's \$80M collateral-reuse mechanism could not occur the same way in Move. Counter-evidence found and included for balance: the Typus protocol exploit (Sui Move, Oct 2025) confirms language-level resource safety does not extend to logic outside the resource model itself, such as oracle price access control. Added as an explicit translation note to Pattern 2 — Move-based protocols should not be assumed guilty by EVM-pattern default, nor cleared by language alone.

9. Aave on Aptos — First Deliberate Single-Protocol Move-Chain Dry Run

Real findings: Aave V3 launched on Aptos August 2025, a complete Move rewrite, audited, with Chainlink price feeds. Initial assets APT, sUSDe, USDT, USDC. Pattern 1 requires checking sUSDe's specific bridge mechanism onto Aptos separately (same Inherited Risk treatment as the Ethereum deployment's KelpDAO exposure) — not yet completed. Pattern 3 NOT APPLICABLE, same single-pool DAO-governed model as Ethereum. No incident history specific to the Aptos deployment found.

Net Effect on the Methodology

Of the patterns and checks examined in this research round: two were promoted to full confidence (Lending P3, Derivatives P2), one was searched and correctly left unpromoted (Insurance P3), one was built new after passing a universality test (Supply Chain Risk), one new watch-item was added (Audit/Bounty Scope Coverage), one candidate was tested and retired (Flash Loan Resistance), one historical mis-citation was found and corrected (Cetus), and one cross-chain translation gap was closed with real, balanced evidence (Lending P2's Move note). Every change traces to a named, dated, dollar-quantified case or an explicitly documented negative search result — consistent with this methodology's standing rule that no pattern is trusted without real validation.

Foundational Pattern Discovery Research

This is the original research base that led to the discovery and validation of every pattern in the DFJ Pattern Checker skill — the real, named, dated incidents whose study produced each of the eight category pattern libraries. Every pattern in this skill exists because a real exploit was studied first; no pattern was invented and then retrofitted with a supporting case. This document is the evidence trail.

The Founding Principle

Six professional audit firms missed the Euler Finance donateToReserves flaw before it was exploited for \$197M. This skill would not have caught that either — it has no prior pattern to match against for a genuinely novel vulnerability class. This single fact defines what the skill is and is not: a pattern-matching tool against known, validated failure modes, not a vulnerability-discovery tool. Every pattern below exists because it already happened at least once, in public, with a quantifiable loss.

Lending

Case	Loss	What It Revealed
Aave / KelpDAO rsETH	\$292M (Apr 2026)	The founding case of the entire methodology. A lending protocol's own code was never compromised — the loss came from accepting a collateral asset whose backing depended on a separately compromised bridge. Revealed Pattern 1 (Collateral Concentration in Cross-Chain-Dependent Assets) and the need for an Inherited Risk universal check distinct from any category table.
Cream Finance (AMP listing)	\$34M (Aug 2021)	First confirmation of donation/balance-inflation share-price manipulation.
Cream Finance (yUSD vault)	\$130M+ (Oct 2021)	Same protocol, same root mechanism, six months later — confirmed Pattern 2 as repeatable, not a one-off.
Radiant Capital	\$4.5M (Jan 2024)	Exact match on Pattern 2's flash-loan-funded donation mechanism, independent protocol.
Euler Finance	\$197M (2023)	Confirmed OUT OF SCOPE — a pure code-logic bug (missing health check in donateToReserves) missed by six audits. Established the boundary: this skill catches known patterns, not novel code bugs. Belongs in Universal Core audit-weight logic, not a category pattern.

DEX/AMM

Case	Loss	What It Revealed
KiloEx	\$7M (2025)	Spot-price-only pricing exploited across three chains (Base, BNB Chain, Taiko) at the same protocol — founding case for Pattern 1.
PancakeSwap (BCE/USDT pool)	\$679K (Mar 2025)	Independent confirmation of the pool-ratio-distortion mechanism (Pattern 2).
Harvest Finance (downstream)	—	Surfaced during dry-run testing against Curve: a protocol can clear Pattern 1 for its own pricing and still be exploited if a separate, downstream protocol reads its price data unsafely — now built into Pattern 1's definition.

Bridge

Case	Loss	What It Revealed
Ronin	\$625M (2022)	Validator-set compromise — founding case for verifier-independence patterns.
Wormhole	\$320M (2022)	Signature verification bypass.
Multichain	2023	CEO-linked private keys — a single point of failure disguised as a multi-party system.
Orbit Chain	\$81.5M (Jan 2024)	7-of-10 keys compromised — demonstrated that even a seemingly robust multisig threshold can fail if too many keys are practically reachable by one attacker.
Radiant Capital	\$53M (Oct 2024)	Signing-interface spoofing — a privileged signer deceived by a compromised interface into approving a malicious transaction.
Bybit	\$1.4–1.5B (Feb 2025)	Independently confirmed the exact same signing-interface-spoofing mechanism as Radiant — the single largest crypto theft in history, validating the pattern at the highest possible stakes.
Secret Network/Axelar IBC	\$4.67M (Jun 2026)	Disabled verification check, Cosmos-native — confirmed the pattern translates across non-EVM architectures.

Derivatives

Case	Loss	What It Revealed
Hyperliquid (3 incidents)	incl. \$4.9M POPCAT (2025)	Repeated community-vault drains at the same protocol — founding evidence for Pattern 1 (Leverage/Liquidity Mismatch).

Case	Loss	What It Revealed
Gains Network/gTrade	\$19.3M vault exposure	EXACT MATCH — leverage up to 500x quantified against vault depth; the Luna/UST 2022 event proved the designed backstop was disabled precisely when needed.
GMX V1	\$42M (Jul 2025)	Confirmed OUT OF SCOPE — reentrancy/vault accounting bug in legacy code, same boundary as Euler.

Stablecoin

Case	Loss	What It Revealed
USR / Resolv Labs	\$24M, 95% depeg (Mar 2026)	Founding case for the mint-authority/collateral-liquidity pattern pairing.
StablR	\$13.5M (May 2026)	Same root pattern, two months apart — confirmed repeatability.
Angle Protocol/EURA	(EXACT MATCH)	74% of USDC reserves deposited in Euler Finance via automated strategy — an immediate agEUR depeg when Euler was exploited, despite Angle's own code being uninvolved. Protocol later entered formal wind-down.
apxUSD & MIM	Validated negative result	Both depegged the same week with no exploit, no compromised key, no unauthorized mint — collateral simply repriced under market stress. Confirmed a real, clean NOT PRESENT case distinguishing genuine market risk from a scoreable pattern.

Yield Aggregator

Case	Loss	What It Revealed
Yearn (legacy vault)	\$9M (Dec 2, 2025)	Founding case for deprecated-strategy-retirement risk.
Yearn (yETH pool)	\$9M (Nov 30, 2025)	Same protocol, three days apart, a genuinely different root cause — confirmed two distinct failure modes can coexist at one protocol in close succession.

RWA (Real-World Asset)

Case	Loss	What It Revealed
Zoth RWA restaking	\$8.5M (Mar 2025)	Compromised private key — described in its own post-mortem as a “classic operational security failure.”

Case	Loss	What It Revealed
Centrifuge private credit pools	Real defaults, 2023	EXACT MATCH — a single price-admin key submitted off-chain-calculated NAV with no independent on-chain verification. Harbor Trade Credit Series 2 and ConsolFreight CF4 both defaulted; on-chain NAV did not reflect impaired off-chain assets until governance intervened, blocking investor redemptions.

Insurance

Founding research here produced a deliberate non-finding: sector-wide capital adequacy data on Nexus Mutual (the largest DeFi insurer, ~\$81.56M total capital pool, ~\$18M in cumulative claims paid since 2019) shows the real risk is capital scale, not bad-faith claims denial. Against the \$292M KelpDAO exploit alone — 16x the insurer's entire seven-year claims history in one incident — the structural mismatch is the real finding. No case of a major DeFi insurer denying a legitimate claim in bad faith was found; Nexus Mutual's actual record (Yearn, FTX, Euler, Rari Capital, Arcadia Finance) shows consistent payouts. This is why the file deliberately does not include a “claims denial” pattern — it was researched and not found, not assumed absent.

How This Became a Skill, Not Just a List

The skill's actual design choices all trace back to specific moments in this research, not abstract principles. The category-by-category structure exists because incidents cluster by mechanism, not by protocol type. The EXACT/SIMILAR/NOT PRESENT match-status system exists because Aave's own KelpDAO exposure was one step removed from KelpDAO's direct Bridge finding — a real case that needed a real distinction between direct and inherited evidence. The Inherited Risk and Concentrated Control Risk universal checks exist because the founding Lending and Bridge research kept surfacing risks that didn't belong to any single category. The “operating status check before scoring” rule in SKILL.md's workflow exists because enough protocols turned out to be already shut down, frozen, or in wind-down during testing that this had to become a mandatory first step, not a judgment call. Nothing in this skill was designed first and validated after — every structural decision traces back to a real incident in the tables above.

Concentrated Control Risk, Inherited Risk & Supply Chain Risk

Three checks applied to every protocol, regardless of category — alongside (not instead of) whichever category-specific penalty table applies. Each has its own ceiling of **-5**. Combined with a category table's **-15** ceiling, the full penalty budget closes at **-30**, up from **-25**. This expansion was deliberate, not a process drift: a fourth candidate (Flash Loan/Economic Attack Resistance) was considered and retired earlier because it failed to apply to two full categories (Bridge, RWA). Supply Chain Risk was tested the same way and passed — it has a real, validated mechanism in every category, including the two that disqualified the earlier candidate. See the Scoring Procedure document for the full reconciliation.

1. Concentrated Control Risk — Ceiling: -5

The question is always the same, regardless of which layer it shows up at: how many genuinely independent parties have to collude to take a severe, unilateral action over user funds or the system itself? This is scored as its own independent finding, separate from any category-specific pattern, because it has been validated at three structurally different layers — not as a side effect of any single category.

Layer	Validating Case
Lending governance vote	Solend's SLND1 proposal to seize a whale's account passed with 97.5% approval — one wallet cast 88% of the votes. Reversed the next day after backlash.
Bridge / stablecoin admin multisig	Frax's 3-of-5 core team multisig controls the Comptroller and Timelock, and pushed an undisclosed contract patch in December 2025.
Base-layer validator / consensus	A custom L1 (Hyperliquid) where core contributors hold a large, concentrated share of the staked token determining block production and consensus weight.

How to score: identify any mechanism — a governance vote, an admin multisig, a validator/staking weight system — that could let a concentrated set of parties take a severe, unilateral action. Check how concentrated the actual power is, and whether friction (cooldown, supermajority, independent veto) would slow or block unilateral action.

Match Status	Deduction
EXACT MATCH — mechanism exists, power is verifiably concentrated, no friction	-5

SIMILAR MATCH — mechanism exists but concentration is undisclosed, or friction is untested **-2.5**

NOT PRESENT — no mechanism, or power is verifiably distributed **0**

2. Inherited Risk — Ceiling: -5

Inherited Risk is scored differently from every other line in this methodology, and that difference is deliberate. It is not its own independently-evidenced pattern — it is a **capped pass-through** of a finding that already exists in another protocol's own category table. The purpose is narrow: capture real risk a protocol takes on by depending on something else, without implying the dependent protocol operates that other thing itself.

How to score: identify any protocol the one being checked materially depends on (a yield aggregator's underlying lending market, a stablecoin's reference price source, a collateral asset's own cross-chain backing). Take whatever match status that underlying dependency would score in its own category table, and apply that same match status here — capped at this -5 ceiling, regardless of how severe the source finding was in its own table.

Source Finding (in its own category table)	Inherited Deduction Applied Here
EXACT MATCH	-5 (full ceiling)
SIMILAR MATCH	-2.5
NOT PRESENT	0

Note that even an EXACT MATCH source finding caps at -5 here, even though the same finding might cost more (e.g., -15) inside the underlying protocol's own category table. This is intentional: a protocol that depends on a severely compromised system is at real risk, but is not as exposed as the system that is the severely compromised one. The cap reflects that proportionality, not a judgment that the risk doesn't matter.

3. Audit/Bounty Scope Coverage (Watch-Item) — Ceiling: -2

Added during v2.2 gap reconciliation. Checks whether a protocol's actually-deployed contracts are fully covered by its claimed audits and bounty program, or whether legacy/deprecated contracts and newer deployments have quietly fallen outside scope. Capped lower than Inherited Risk and Concentrated Control Risk, reflecting its narrower, more procedural nature — this is a disclosure gap, not a structural power imbalance.

Validating Case	What Happened
Cork Protocol (\$12M)	Exploited contracts were reportedly out of the protocol's own bounty scope.

Abracadabra	Deprecated CauldronV4 logic left unaudited for roughly two years while newer features kept getting reviewed.
-------------	--

GMX V1 (\$42M)	Legacy contracts possibly excluded from the bounty program's scope.
----------------	---

Match Status	Deduction
SIMILAR MATCH (ceiling) — confirmed gap between deployed contracts and audited/bounty-covered contracts	-2
NOT PRESENT — audit and bounty scope explicitly confirmed to cover all currently deployed, fund-holding contracts	0

This check cannot reach EXACT MATCH — it is inherently a binary disclosure-gap question (is everything in scope, or not), not a severity tier beyond that. It is excluded from every category's core total, the same as any other watch-item.

4. Supply Chain Risk — Ceiling: -5

Checks whether a protocol's user-facing frontend, browser extension, or build/release pipeline can be compromised through a third-party dependency or vendor relationship — distinct from a smart contract vulnerability, and distinct from Bridge Pattern 5 (Signing-Interface Spoofing). Signing-Interface Spoofing targets a specific privileged signer during a specific high-value transaction; Supply Chain Risk targets the shared production infrastructure that every ordinary user relies on, continuously. Confirmed to apply across all eight categories, including the two (Bridge, RWA) that disqualified the earlier Flash Loan Resistance candidate from universal status.

Validating Case	What Happened
Trust Wallet Chrome Extension (\$7M, Dec 2025)	A leaked Chrome Web Store API key allowed an external party to publish a malicious extension version that bypassed Trust Wallet's internal manual release process entirely. Confirmed by Trust Wallet; users refunded.
Polymarket Frontend (\$3.1M, June 2026)	A compromised third-party vendor injected malicious JavaScript into Polymarket's website frontend, draining funds from 11 confirmed user wallets — the platform's second serious security failure in five weeks.

How to check: identify whether the protocol's production frontend, browser extension, or release pipeline depends on third-party vendors, npm packages, or external build infrastructure with the ability to push changes directly to what users see or sign. Check whether release processes require independent review (a single compromised key or account should not be sufficient to publish a live update), and whether dependency/build integrity is monitored (lockfiles, version pinning, automated scanning).

Match Status	Criteria	Deduction
--------------	----------	-----------

EXACT MATCH	A confirmed, named, dated supply-chain compromise of this protocol's own frontend, extension, or release pipeline has occurred, with no documented process fix since	-5
SIMILAR MATCH	No confirmed incident, but release process relies on a single key, account, or vendor with the ability to push live changes with no independent review step confirmed	-2.5
NOT PRESENT	Documented multi-party release review, dependency pinning/lockfiles, and build integrity monitoring are confirmed, not merely asserted	0

Both validating cases involved the protocol's own infrastructure (a release pipeline, a vendor relationship) rather than a user's personal device or credentials — this check is about the protocol's process integrity, not general end-user security hygiene.

Worked Example — Aave's Full Penalty Picture

Aave does not operate a bridge, a derivatives engine, or any other category-specific infrastructure of its own beyond Lending. Its full penalty total combines:

Line	Basis	Deduction
Lending (own category table)	Collateral Asset Risk — SIMILAR/EXACT findings tied to rsETH concentration	see Lending table
Inherited Risk	KelpDAO's own Bridge P1 finding (SIMILAR MATCH) passes through, capped here	-2.5
Concentrated Control Risk	Aave's own governance/multisig structure, scored independently	see assessment
Supply Chain Risk	No confirmed frontend/release-pipeline compromise found; release process review not independently verified — NOT PRESENT pending further disclosure, not penalized without evidence	0

Each line is scored independently, against its own ceiling, and summed only at the end. No single dependency or governance structure can be counted twice across these four lines.

Lending — Category Penalty Table (v1)

Converts findings from the Lending pattern reference file into point deductions. Category-specific ceiling: **-15**, fully allocated across three validated patterns (no watch-items remain in this category as of this revision). Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Architecture Check — Before Scoring

Not every lending protocol has a single shared pool. Permissionless market-creation frameworks (Morpho Blue, Silo, JustLend V2) let anyone deploy isolated markets, each with independently-chosen collateral and risk parameters. For these, Pattern 1 must be scored **per individual market**, not as a protocol-wide aggregate — a single “score” for the whole protocol is not meaningful for this architecture type. For single-pool protocols (Aave, Compound), Pattern 1 applies at the protocol level as below.

Weighting Rationale

Three scoreable patterns, all now fully validated. Pattern 1 is the case that originated this entire methodology; Pattern 2 has two independent confirmations at the same protocol plus a cross-chain confirmation; Pattern 3 (Curator/Allocator Risk) was promoted from watch-item status after two independent, real, dollar-quantified incidents (Stream Finance, Resolv) confirmed the mechanism — see note below.

Pattern	Max Deduction	Why This Weight
P1 — Collateral Concentration in Cross-Chain-Dependent Assets	-7	The case that started this methodology. Aave/KelpDAO: \$123.7M–\$230.1M in bad debt from a single concentrated collateral asset with unresolved bridge risk. The highest-profile, most consequential pattern in the file.
P2 — Exotic/Non-Standard Token Integration Risk	-4.5	Confirmed twice at the same protocol (Cream Finance, \$34M then \$130M+, six months apart) plus an independent cross-chain confirmation (Solend/USDH, Solana, \$1.26M). Real, repeatable, multi-chain.

Pattern	Max Deduction	Why This Weight
P3 — Curator/Allocator Risk	-3.5	Promoted from watch-item status: confirmed twice, independently, across different curators (Stream Finance xUSD collapse, Nov 2025, ~\$285M ecosystem exposure; Resolv USR exploit, March 2026, 15+ vaults across 4 named curators). Both cases confirm Morpho Blue's isolated-market design contained damage to the affected vaults specifically — a curator judgment failure, not a platform failure.
Category Total	-15	

***P3's promotion, explained:** until this reconciliation, Curator/Allocator Risk was capped at SIMILAR MATCH pending a real validating incident — the same bar every pattern in this methodology must clear. Two independent, real, dollar-quantified cases now confirm the mechanism at full strength: EXACT MATCH is reachable for a curator with a confirmed history of allocating into a market that was later exploited or whose collateral depegged with resulting bad debt.*

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Aave (Direct Lending Findings Only)

From the Aave pattern check completed earlier in this project — this covers Aave's **own** Lending-category findings only. Aave's Bridge-related exposure (via rsETH/KelpDAO) is scored separately through the universal Inherited Risk line, not duplicated here — see the *Universal Penalty Checks* document.

Pattern	Finding	Deduction
---------	---------	-----------

P1 — Collateral Concentration	SIMILAR MATCH (rsETH concentration with e-mode leverage; bridge dependency confirmed but Aave's own exposure check is a step removed)	-3.5
P2 — Exotic Token Integration	NOT PRESENT (no ERC-777/donation-manipulable collateral identified)	0
P3 — Curator/Allocator Risk	NOT PRESENT (Aave is a direct-market protocol, not a curated vault product)	0
Lending category total		-3.5 / -15

Aave's Lending category score is comparatively light at -3.5/-15 — the heavier, more consequential part of its rsETH exposure is captured by the Inherited Risk line (KelpDAO's own Bridge finding, capped at -2.5), not by Aave's own Lending table. This split reflects what actually went wrong: a collateral-acceptance decision compounded by a dependency's bridge failure, scored as two distinct, non-duplicated lines.

DEX/AMM — Category Penalty Table (v1)

Converts findings from the DEX/AMM pattern reference file into point deductions. Category-specific ceiling: **-15**. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Weighting Rationale

Two scoreable patterns, both validated against real, dated incidents — no watch-items needed in this category. Pattern 1 carries substantially more weight: a real, cross-chain confirmed incident (KiloEx, across three chains), plus a documented downstream-integrator extension (a protocol can clear Pattern 1 for its own pricing and still be exploited if a different protocol reads its price data the wrong way) that broadens its real-world surface considerably beyond Pattern 2's single, narrower incident.

Pattern	Max Deduction	Why This Weight
P1 — Spot-Price-Only Pricing (No TWAP)	-10	KiloEx (\$7M, across three chains — Base, BNB Chain, Taiko) confirms the core mechanism at real scale and across multiple deployments of the same protocol. Also covers a separately validated downstream-integrator failure mode (Harvest Finance, \$500K) — a protocol can pass this pattern for its own pricing and still be exploited if another protocol reads its data unsafely. Cetus Protocol's \$223M loss was previously cited here but has been removed after reconciliation confirmed its actual root cause was an unrelated checked-arithmetic bug, not spot-price manipulation — see the reference file's "What this file does NOT cover" section. The broadest pattern in this file by real-world surface, even at a corrected, narrower evidence base.
P2 — Pool Ratio Distortion via Auxiliary Mechanism	-5	One confirmed incident (PancakeSwap BCE/USDT, \$679K) — real and distinct from P1 (the manipulation vector is a burn/fee mechanism, not flash-loan-funded price movement), but narrower in scope and lower in confirmed dollar impact.
Category Total	-15	

Note on Pattern 1's downstream-integrator extension: this is scored as part of Pattern 1, not a separate line, because it's the same underlying risk (unsafe consumption of manipulable price data) viewed from the integrator's side rather than the source pool's side. A protocol can score NOT PRESENT for its own pricing mechanism and still take the full P1 deduction if it consumes another pool's data unsafely — these are evaluated independently for any given protocol, not averaged together.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Curve Finance

From the Curve Finance dry run completed earlier in this project: Curve's EMA oracle was confirmed manipulation-resistant via Certora and ChainSecurity audits, and no Harvest-style downstream misread was found among current integrators at the time of checking.

Pattern	Finding	Deduction
P1 — Spot-Price-Only Pricing	NOT PRESENT (confirmed EMA oracle, audited; no unsafe downstream integration found)	0
P2 — Pool Ratio Distortion	NOT PRESENT (fee burns require governance/admin action; rebasing tokens handled via separate admin-balance tracking, not raw reserve inference)	0
DEX/AMM category total		0 / -15

Curve is the cleanest result obtained anywhere in this project's dry-run testing — a genuine 0/-15, backed by named audit firms and code-level verification rather than vendor language. Worth noting explicitly: this is a real NOT PRESENT, not an absence of testing — Curve was checked against both patterns and cleared each on specific, verifiable evidence.

Bridge — Category Penalty Table (v1)

Converts findings from the Bridge pattern reference file into point deductions. Category-specific ceiling: **-15**. This sits alongside two universal checks — Concentrated Control Risk (0 to -5) and Inherited Risk (0 to -5) — applied after the 97-point Universal Core score. Combined ceiling across all three: **-25**. See the companion document, *Universal Penalty Checks*, for those two lines.

Weighting Rationale

Bridge has the deepest validation in the entire pattern library — 4 scoreable patterns (Detection/Response Time is comparative and informational only, and is **not** scored here), tested against 9+ real incidents across 2 architecture families. Weights below are not equal; they reflect actual evidence strength, not pattern count, and have been scaled down from an earlier /25 draft to fit the finalized /15 category ceiling — relative weighting between patterns is preserved.

Pattern	Max Deduction	Why This Weight
P1 — Verifier/Validator Independent-Operator Count	-5.5	Highest-evidence pattern in the file. Validated by the two largest bridge losses on record (KelpDAO \$292M, Ronin \$625M). The single most consequential, most-cited failure mode in this entire library.
P5 — Signing-Interface Spoofing	-5	Validated independently twice (Radiant \$53M, Bybit \$1.4–1.5B), same root mechanism, four months apart — the strongest cross-validation of any pattern in the file, even though P1's absolute dollar losses are larger.
P3 — Key Custody Architecture	-3	Real validating cases (Multichain, Orbit Chain), but flagged in the source file as never once clearing NOT PRESENT across 6+ independently tested protocols — suggesting either a pervasive industry gap or an uncalibrated bar.
P2 — Failover/Degradation Behavior Under Stress	-1.5	Real and validated (KelpDAO's DDoS-to-compromised-node mechanism specifically), but the narrowest and most situational of the four — requires a specific combination of conditions rather than a standing structural property.
Category Total	-15	

Scoring Rule Per Pattern

This rule applies uniformly across every category table, not just Bridge:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. When exactly between two increments (e.g., -0.75), round toward the larger deduction — treat ties as the more conservative outcome.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — but must be disclosed separately as “unverified,” never silently treated as equivalent to NOT PRESENT

Worked Example — Aave (Bridge Exposure via rsETH / KelpDAO)

Aave does not operate bridge infrastructure itself, so it has no direct entry in this table. Its rsETH-related risk is scored through the universal **Inherited Risk** line instead: KelpDAO's own Bridge P1 finding (SIMILAR MATCH) passes through, capped at the Inherited Risk ceiling of -5 rather than Bridge's own -15 ceiling.

See the companion document, Universal Penalty Checks, for how the Inherited Risk pass-through calculation works. This avoids double-counting — Aave is not scored as if it operates a bridge, only as if it depends on one.

Worked Example — Radiant Capital (Operates Its Own Bridge Infrastructure)

Pattern	Finding	Deduction
P1 — Verifier/DVN Independence	SIMILAR MATCH (post-hack 5-DVN, identities undisclosed)	-3
P2 — Failover Behavior	SIMILAR MATCH (no automated circuit breaker for access-control attacks)	-1
P3 — Key Custody	SIMILAR MATCH (4-of-7 post-hack, storage partially disclosed)	-1.5
P5 — Signing-Interface Spoofing	EXACT MATCH (confirmed exploited mechanism, Oct 2024)	-5
Bridge category total		-10.5 / -15

This is a meaningfully severe Bridge penalty, appropriately so — Radiant is the only protocol in this library with a **confirmed, exploited** instance of Pattern 5 at full weight. The score reflects that Radiant didn't just carry theoretical bridge risk; it materialized. This Bridge category result combines with Radiant's own

Concentrated Control Risk and Inherited Risk findings (scored separately, see companion document) to produce its full penalty total.

Derivatives — Category Penalty Table (v1)

Converts findings from the Derivatives pattern reference file into point deductions. Category-specific ceiling: **-15**, fully reachable through three validated patterns (P1, P2, P3) — see below. No watch-items remain in this category as of this revision. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Weighting Rationale

All three patterns are now confirmed against real, named, dated incidents — Pattern 1 from the start, and Patterns 2 and 3 after this reconciliation (see below). No watch-items remain in this category.

Pattern	Max Deduction	Why This Weight
P1 — Leverage/Liquidity Mismatch on Thin Order Books	-8	The most consequential validated pattern in this category — three independent incidents at the same protocol (Hyperliquid, 2025, including the \$4.9M POPCAT case) plus a separately confirmed EXACT MATCH at a different protocol (Gains Network, quantified up to 500x leverage against a \$19.3M vault, with the Luna/UST 2022 event proving the designed backstop fails precisely when needed).
P2 — Oracle/Mark Price Latency Under Leverage	-4	Confirmed twice, independently (KiloEx, \$7.4M, April 2025, single-protocol; the October 2025 market-wide liquidation cascade, \$19.3B, exploiting the same single-source mark-price mechanism at systemic scale). Weighted below P1 since one validating case is market-wide rather than protocol-specific.
P3 — Asymmetric/Binary Settlement Risk	-3	Promoted from watch-item status: confirmed twice at the same protocol, one year apart (dYdX's TRUMPWIN-USD, Oct–Nov 2024; dYdX's own 2025 World Series perpetual announcement confirming a direct, named ADL process fix and proposed compensation following TRUMPWIN). Weighted lowest of the three patterns — narrower in scope, applying only to binary/prediction-style settlement markets, not all derivatives products.
Category Total	-15	

P2's promotion, explained: until this reconciliation, Oracle/Mark Price Latency was capped at SIMILAR MATCH pending a real validating incident. Two independent, real, dollar-quantified cases now confirm the mechanism: EXACT MATCH is reachable for a protocol relying on a single, unaggregated price source for liquidation-triggering valuations.

P3's promotion, explained: until this reconciliation, Asymmetric/Binary Settlement Risk was capped at SIMILAR MATCH pending a second validating case. dYdX's own later announcement — explicitly naming TRUMPWIN as the reason for an ADL process redesign and proposing trader compensation — confirms the originally disclosed risk materialized into a real problem at the same protocol, the same validation standard Cream Finance's two same-protocol incidents met for Lending Pattern 2.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — dYdX v4

From the dYdX v4 dry run completed earlier in this project: leverage caps tighten dynamically with open interest (a confirmed, disclosed mechanism), and mark price aggregates across seven independent exchanges with validator consensus.

Pattern	Finding	Deduction
P1 — Leverage/Liquidity Mismatch	NOT PRESENT (leverage dynamically tied to open interest, the reference example for clearing this pattern)	0
P2 — Oracle/Mark Price Latency	NOT PRESENT (seven-exchange aggregation, the reference example for clearing this pattern)	0
P3 — Binary Settlement Risk	SIMILAR MATCH (TRUMPWIN-USD's payout-shortfall risk materialized, requiring a real ADL process fix per dYdX's own later announcement — but that fix is itself the documented process improvement this pattern's SIMILAR MATCH tier describes, not an unresolved EXACT MATCH)	-1.5

Derivatives category total	-1.5 / -15
----------------------------	------------

dYdX clears the validated Pattern 1 and Pattern 2 cleanly, and its small residual penalty comes entirely from Pattern 3 — a real, now-validated risk specific to one market type (binary/prediction markets), not the protocol's core leverage or oracle design. dYdX's own response to TRUMPWIN's payout-shortfall risk — a documented ADL process redesign — is precisely what keeps this finding at SIMILAR MATCH rather than EXACT MATCH: a real problem that materialized, with a real, confirmed fix.

Stablecoin / CDP — Category Penalty Table (v1)

Converts findings from the Stablecoin pattern reference file into point deductions. Category-specific ceiling: **-15**, split into a -13.5 core total (two validated patterns) plus a -1.5 watch-item — see below. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Critical Distinction Before Scoring

A depeg is **not** automatically evidence of a security failure. A stablecoin trading under \$1 because its collateral legitimately repriced in a transparent, solvent market move (apxUSD, MIM — June 2026, no exploit, no compromised key) is a different risk category entirely from a depeg caused by an unbacked mint (USR, StabIR). Always determine *why* a depeg happened before applying any pattern below — conflating the two is a real methodology error, not a minor imprecision.

Weighting Rationale

Pattern 1 has the strongest evidence in this file: two independent, confirmed incidents, same root mechanism, two months apart. Pattern 2 has one validated case, but it is a carefully distinguished, real structural-fragility finding — not weaker evidence, just a narrower one. Pattern 3 is explicitly capped at SIMILAR MATCH in the source file itself, with no EXACT MATCH criteria defined — tracked as a watch-item.

Pattern	Max Deduction	Why This Weight
P1 — Mint Authority Control Risk	-8	Two independent, confirmed incidents (USR \$24M, StabIR \$13.5M), same exact mechanism, two months apart — the same standard of cross-validation that earned Bridge's signing-spoofing pattern its high weight. The most severe and best-evidenced pattern in this file.
P2 — Collateral Liquidity Depth Risk	-5.5	One validated case (apxUSD/MIM), but a genuinely distinct and carefully-reasoned structural risk — explicitly not the same as Pattern 1, and deliberately scored without exploit-implying language since no security breach occurred in the validating case.
Core Total (P1 + P2)	-13.5	

Important wording constraint on P2: per the source file, findings under this pattern must never use exploit language (“hack,” “drain,” “compromised”). It describes a structural fragility, not a security breach — use “liquidity risk” or “redemption risk” in any output, consistent with what actually happened in the validating case.

Watch-Item — Not Included in Core Total

Off-Chain Operational/Counterparty Dependency Risk applies specifically to synthetic or strategy-backed stablecoins (e.g., a delta-neutral hedge requiring active off-chain management). It is real and disclosed, but the source file states explicitly that it “currently has no EXACT MATCH criteria defined” — no realized loss incident validates a specific failure threshold yet.

Pattern	Ceiling	Status
P3 (WATCH-ITEM) — Off-Chain Operational/Counterparty Dependency Risk	-1.5	Applies only to synthetic/strategy-backed stablecoins (e.g., Ethena's USDe). Real, disclosed risk factors (custodian concentration, reserve fund adequacy, regulatory disruption) but no confirmed loss incident. Explicitly has no EXACT MATCH criteria in the source file. Ceiling shown is already the SIMILAR MATCH value.

How this combines with the core total: Stablecoin category total = Core Total (0 to -13.5) plus the P3 watch-item (0 to -1.5) if a real finding is present — maximum combined category exposure: -15, the full structural ceiling. P3 is the only pattern in this file that applies conditionally — it should be marked Not Applicable, not scored as 0, for simple on-chain-collateralized stablecoins with no off-chain operational dependency at all.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction (P3: not reachable)
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
NOT APPLICABLE (P3 only)	0, marked distinctly from NOT PRESENT — the pattern does not apply to this stablecoin's backing model at all
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Ethena (USDe)

From the Ethena dry run completed earlier in this project: Ethena's mint/redeem contract is the reference NOT PRESENT example for Pattern 1, but its synthetic backing strategy makes it the clearest real-world case for Pattern 3.

Pattern	Finding	Deduction
P1 — Mint Authority Control	NOT PRESENT (block-by-block caps, price-divergence checks, on-chain whitelist — the reference example for clearing this pattern)	0
P2 — Collateral Liquidity Depth	SIMILAR MATCH (~\$70M accessible secondary liquidity vs. \$4.5–6.3B supply)	-2.75 → -3
P3 (WATCH-ITEM) — Off-Chain Operational Dependency	SIMILAR MATCH (reserve fund ~\$50M vs. \$79M disclosed recommended minimum)	-0.75 → -1
Stablecoin category total		-4 / -15

Both deductions show their raw 50% value alongside the rounded figure actually applied, since neither -5.5 nor -1.5 halves to a clean 0.5 increment on its own (-2.75 and -0.75 respectively) — both round up to the larger deduction per the tie-breaking rule. Ethena's real exposure here is thin secondary-market liquidity relative to its outstanding supply, plus a reserve fund running below its own disclosed recommended minimum — neither is a mint-authority or key-custody failure.

Yield Aggregator — Category Penalty Table (v1)

Converts findings from the Yield Aggregator pattern reference file into point deductions. Category-specific ceiling: **-15**. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Check Before Scoring — Inherited Risk From Underlying Protocols

A yield aggregator's vault wraps an underlying protocol (a lending market, a DEX pool, a staking contract). The vault's own contract can be clean while the underlying protocol carries real risk. This is the same universal Inherited Risk check that applies to every category — for this category specifically, always check the underlying protocol against its own relevant reference file **before** scoring Patterns 1 and 2 below. A clean vault wrapper around a risky underlying protocol is not a clean result.

Weighting Rationale

Two scoreable patterns, both validated against real, dated incidents at the same protocol (Yearn, two distinct exploits three days apart) — no watch-items needed. Pattern 1 carries more weight: it is a governance/process failure (a kill-switch that exists on paper but has no enforced execution path), which is harder to remediate than a pure code-level accounting issue, and it shares its root mechanism with a separately validated finding in the Lending category.

Pattern	Max Deduction	Why This Weight
P1 — Deprecated/Legacy Strategy Retirement Risk	-9	Validated by Yearn's December 2025 exploit (\$9M) — a governance failure, not a hidden bug: the deprecation mechanism existed on paper but had no enforced execution path. Process failures of this kind are structurally harder to fix than code bugs, since the fix requires organizational change, not a patch.
P2 — Donation-Manipulable Vault Share-Price Math	-6	Validated by the same root mechanism as Lending's Pattern 2 (Cream Finance, \$130M+, Oct 2021) applied to vault tokens specifically. Real and confirmed, but this is shared lineage with an already-counted Lending finding rather than fully independent evidence — weighted accordingly.
Category Total	-15	

Note on Pattern 2's shared lineage with Lending: this is not double-counted across categories — a yield aggregator is scored on its own vault share-price logic here; if that same aggregator also operates a lending market directly, that lending market is scored separately, against the Lending table, as its own product. The shared root mechanism (donation-manipulable accounting) is a reason the pattern is well-evidenced, not a reason to combine the two scores.

Note on Yearn's second incident (yETH, \$9M, Nov 30 2025): per the source file, this involved an iterative fixed-point solver bug — closer to a Universal Core code-logic issue (the same boundary as Euler) than a category-specific pattern, and is explicitly listed as something this file does not cover. Do not score it against either pattern above; it belongs in Universal Core audit-weight logic.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Beefy Finance

From the Beefy Finance dry run completed earlier in this project: Beefy's depreciation mechanism is disclosed at the API level (is_eol, eol_date fields) and has been tested in real incidents (Autofarm 2021, Sonne Finance 2024), not just designed on paper.

Pattern	Finding	Deduction
P1 — Deprecated Strategy Retirement	NOT PRESENT (in-place strategy upgrades avoid orphaned vaults; panic() mechanism tested twice in real incidents)	0
P2 — Donation-Manipulable Share Price	SIMILAR MATCH (mooToken formula reads a vault-token balance; internal-ledger-vs-raw-balanceOf distinction not independently verified)	-3
Yield Aggregator category total		-3 / -15

Beefy's only deduction comes from an unverified implementation detail (-3, half of P2's -6), not a confirmed flaw — the Zellic 2024 finding referenced in the source file involved a different mechanism (TWAP tick

deviation) but confirms Beefy's pricing code has previously been vulnerable to a manipulation class, which is why this remains SIMILAR MATCH rather than NOT PRESENT absent direct contract-level verification.

RWA (Real-World Asset) — Category Penalty Table (v1)

Converts findings from the RWA pattern reference file into point deductions. Category-specific ceiling: **-15**. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Weighting Rationale

Two scoreable patterns, both validated against real, dated incidents — no watch-items needed. Pattern 2 carries more weight here, a reversal from most other category tables in this methodology: its validating evidence is the strongest in the file — Centrifuge's private credit pools produced **two** real, dated defaults with blocked investor redemptions (Harbor Trade Credit, ConsolFreight CF4), not just a single incident. Pattern 1 has one direct case but real cross-category corroboration from Stablecoin and Bridge.

Pattern	Max Deduction	Why This Weight
P2 — Oracle/Proof-of-Reserves Integrity Risk	-8	Strongest evidence in this file: Centrifuge's private credit pools produced two real, dated defaults (Harbor Trade Credit, ConsolFreight CF4) where on-chain NAV did not reflect impaired off-chain assets until governance intervention, blocking redemptions — plus an independent \$1.78M Base oracle-misconfiguration case with the same governance-timelock-prolongs-loss mechanism already validated in Yield Aggregator.
P1 — Off-Chain Custody/Operational Key Risk	-7	One direct case (Zoth, \$8.5M) — but the exact same failure mode independently validated in two other categories (Stablecoin's USR/StabIR, Bridge's IoTeX/Multichain), suggesting privileged-key compromise is a cross-category risk worth checking regardless of protocol type, not an RWA-specific quirk.
Category Total	-15	

Out of scope, by design: per the source file, legal enforceability of the underlying on-chain claim (whether it would hold up in a bankruptcy or legal dispute) and business/market risk of the underlying asset class are both explicitly excluded — neither is a pattern-matchable security risk, and assigning either a match rating would overstate what this methodology can actually assess.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Centrifuge (Private Credit Pools Only)

From the Centrifuge pattern check completed earlier in this project: Centrifuge is a two-tier protocol, and this example covers its private credit pools specifically — its liquid asset pools (e.g., BlockTower Andromeda) have meaningfully stronger controls and would be scored separately, as their own product, per the multi-product splitting rule.

Pattern	Finding	Deduction
P1 — Off-Chain Custody/Operational Key Risk	SIMILAR MATCH (asset originator can unilaterally draw liquidity up to debt ceiling; 48-hour timelock and two-guardian multisig provide partial mitigation at the protocol layer)	-3.5
P2 — Oracle/Proof-of-Reserves Integrity	EXACT MATCH (single price-admin key submits off-chain NAV with no independent on-chain verification; confirmed by two real defaults)	-8
RWA category total		-11.5 / -15

Centrifuge's private credit pools score severely at -11.5/-15, appropriately so — this is the only protocol in this entire methodology where a category's EXACT MATCH finding is backed by two separate, real, dated defaults with blocked investor redemptions, not a single incident or a disclosed-but-unrealized risk.

Insurance — Category Penalty Table (v1)

Converts findings from the Insurance pattern reference file into point deductions. Category-specific ceiling: **-15**, split into a -13.5 core total (two validated patterns) plus a -1.5 watch-item — see below. Sits alongside two universal checks — Concentrated Control Risk and Inherited Risk, each 0 to -5 — applied after the 97-point Universal Core score. See the companion document, *Universal Penalty Checks*, for those two lines.

Why This Category Is Different

Every other category in this methodology checks whether a protocol holding or moving user funds can fail. This one checks a different question: whether a protocol whose entire purpose is *absorbing other protocols' failure risk* actually has the capital and structure to do so. An insurer's own contracts can be perfectly secure and it can still fail at its actual job if its capital pool is too small. **Critically: a finding here is not a claim of bad faith.** Nexus Mutual's verified record shows consistent, good-faith claim payouts (including ~\$5M paid on FTX-related claims) — these patterns measure capital scale and structural conflict-of-interest exposure, not whether an insurer has ever acted dishonestly.

Weighting Rationale

Pattern 1 carries the most weight in this file: it is backed by the single most precisely quantified comparison anywhere in this methodology (a real capital pool measured directly against a real, dated, dollar-figure loss — not an estimate). Pattern 2 is a real, evidenced structural finding but inherently softer, since it concerns incentive design rather than a measured capital shortfall. Pattern 3 is explicitly a single-case watch-item.

Pattern	Max Deduction	Why This Weight
P1 — Capital Pool Adequacy Relative to Underwritten Risk	-8	The most precisely quantified finding in the entire methodology: Nexus Mutual's ~\$81.56M capital pool measured directly against the real \$292M KelpDAO loss — 16x its entire 7-year claims history, 3.6x its total capital, in a single incident. Also identifies a structural actuarial flaw (DeFi risk is correlated, not independent, unlike traditional insurance).
P2 — Correlated Claims-Assessor Conflict of Interest	-5.5	Real, structural, evidenced (community-vote models where claim-deniers and capital-providers are the same people) — but a design-incentive finding, not a measured capital shortfall, and inherently softer evidence than P1's direct dollar comparison.

Pattern	Max Deduction	Why This Weight
Core Total (P1 + P2)	-13.5	

Watch-Item — Not Included in Core Total

Voter Apathy/Herding Incentive Risk applies to the inverse structure from Pattern 2 — models where voting power is deliberately separated from financial exposure. Only one validating case exists (Neptune Mutual, closed ~Nov 2024) — every other pattern in this methodology required two independent confirmations before being trusted at full weight.

Pattern	Ceiling	Status
P3 (WATCH-ITEM) — Voter Apathy/Herding Incentive Risk	-1.5	Single case (Neptune Mutual): voters rewarded for majority alignment regardless of accuracy, with no capital at stake either way. A real, distinct failure mode from P2 (apathy vs. motivated denial), but unconfirmed at a second protocol. Cannot reach EXACT MATCH. Ceiling shown is already the SIMILAR MATCH value.

Note — P2 and P3 are mutually exclusive by structure, not independently scoreable together: P2 applies when voting power and financial exposure are combined (the conflict is motivated denial); P3 applies when they are deliberately separated (the failure is apathy instead). The same insurer cannot score on both — check which structure applies first, then apply only the corresponding pattern.

Scoring Rule Per Pattern

Same rule applied across every category table:

Match Status	Deduction Applied
EXACT MATCH	Full listed deduction (P3: not reachable)
SIMILAR MATCH	50% of listed deduction, rounded to nearest 0.5. Ties round toward the larger deduction.
NOT PRESENT	0
CANNOT DETERMINE	0 deduction — disclosed separately as “unverified,” never treated as NOT PRESENT

Worked Example — Nexus Mutual

From the Nexus Mutual pattern check completed earlier in this project — the only protocol in this entire methodology that returned EXACT MATCH on both patterns in its category. Both findings are structural, not evidence of bad faith.

Pattern	Finding	Deduction
P1 — Capital Pool Adequacy	EXACT MATCH (~\$81.56M capital pool vs. \$292M KelpDAO loss — 3.6x smaller than a single real incident; no reinsurance or claim-capping mechanism found)	-8
P2 — Correlated Claims-Assessor Conflict	EXACT MATCH (claims assessed by NXM stakers whose own locked capital is directly reduced by a successful claim; no parametric or independent-assessor option found)	-5.5
P3 (WATCH-ITEM) — Voter Apathy	NOT APPLICABLE (Nexus Mutual's structure combines voting power with financial exposure — the P2 structure, not the P3 structure)	0
Insurance category total		-13.5 / -15

Nexus Mutual's near-maximum category score (-13.5/-15, the highest of any protocol scored in this entire methodology) reflects two real structural findings, not an allegation of wrongdoing — its actual claims-payment record, including the FTX case, shows the opposite. The finding is that the capital base could not withstand a claim at a scale the DeFi ecosystem has already proven possible, and that its claims process has a built-in structural conflict, however well it has performed at smaller scale to date.

Scoring Procedure: Steps, Rules, and Verification Gates

This document exists because of real, caught mistakes — not as a hypothetical best practice. Two arithmetic errors and one uncalibrated score shipped in an earlier scoring pass before being caught by review, not by the process itself. A sound procedure should produce the same result regardless of who runs it, and should catch errors before they ship, not after. The steps below are designed to do that.

Step 0 — Multi-Product Detection (Run This Before Step 1)

Before scoping anything, actively search for whether the protocol has launched additional products beyond the one initially prompting the research — do not rely on the protocol being “well known” as a reason to skip this. Specifically search for: recent product launches (the last 12 months are the highest-risk window, since newer products are the ones most likely to be missed), named vaults or sub-products with their own deposit mechanics, and named third-party curators or strategy providers integrated into the protocol's offering.

***The specific error this gate catches:** Lido was scored as a single product (core staking, with one inherited-risk finding for a side exposure) for an entire research pass, when it had in fact already launched two additional, named, separately-operated products (EarnETH and EarnUSD) months earlier — one of which had its own real, undocumented third-party curator (Mellow) and its own real incident history distinct from core staking. This was only caught when a later, unrelated review asked “does Concentrated Control Risk apply the same way across all of this protocol's products” — a question that presupposes the product list is already complete, which it was not.*

Gate: run one explicit search for “[protocol name] new product 2026” or “[protocol name] launches” before finalizing scope, even for protocols that seem simple or well-understood from prior knowledge. A protocol's reputation for being single-product is not evidence that it still is one — it is exactly the kind of stale assumption this gate exists to interrupt.

Step 1 — Determine Scope Before Any Research

Identify whether the subject is a single protocol or a multi-product ecosystem (more than one materially distinct product under one brand — different TVL, different function, different contracts). If multi-product, list every product that will be scored **before** researching any of them. Do not discover the product list partway through.

Gate: if scope changes mid-process (a new product is discovered), stop and restart Step 1 rather than patching the in-progress work.

Step 2 — Research Before Scoring, Never Concurrently

For each product: research real audit history (named firms, dates), real incident history (named, dated, dollar-quantified if applicable), and real governance/admin structure (named roles, thresholds, demonstrated actions if any). Write all of this down as plain findings **before** assigning a single number. Numbers should be the last thing produced for each product, not generated alongside the research.

Gate: if a number is being written before its supporting evidence is written, stop — this is the single most common source of uncalibrated scores.

Step 3 — Universal Core Calibration Check

Before finalizing any Universal Core (Foundation + Active) score, compare it against at least one already-scored protocol with a similar profile, using the table below as the standing reference — not from memory, from this table:

Profile	Reference Gross Score Range	Reference Example
Many audits, formal verification, long clean track record, no admin backdoor	88–93	Uniswap (91)
Many audits, formal verification, long clean track record, some admin/steward concentration	83–88	Aave (87), Lido Core Staking (83)
Several audits (2–3), recent, no confirmed incident	73–80	Fraxswap (78 gross), sfrxETH (75 gross)
One audit (even top-tier), aging, no confirmed incident	73–78	Fraxswap pre-correction error: scored 70 — too low for this profile
Audits exist, but a real disclosed structural gap or historical finding	65–72	Fraxlend (70 gross)
New product (<12 months), no dedicated audit, but zero disclosed structural gap and zero incidents either direction — genuine uncertainty, not a known weakness	55–65	Lido EarnUSD pre-correction error: scored 46 — too low, scored as if a known gap had been found when none had

The specific error this gate catches: Fraxswap (one clean audit, zero incidents) and Fraxlend (two audits, one real disclosed gap) were independently scored to the identical 70 gross before correction — despite representing different rows in the table above. Neither score was checked against the other, or against this table, before publishing.

Why genuine uncertainty scores below a known, bounded gap, not above it: this ordering is non-obvious and must be stated explicitly so it isn't re-derived inconsistently each time. A protocol with a real, disclosed structural weakness (Fraxlend's permissionless exotic-token exposure) is a known risk that can be reasoned about, sized, and monitored. A protocol with zero audits and zero incident history either way carries unknown risk — there is no evidence it's safe, only an absence of evidence it isn't. Absence of bad news is not the same as a clean record, and should not be scored as if it were.

The specific error this row corrects: Lido EarnUSD (launched March 2026, no dedicated audit, zero disclosed weaknesses, zero incidents) was originally scored at 46 gross — below Fraxlend's 70 gross, despite Fraxlend having an actual, named, disclosed structural gap and EarnUSD having none. The original score treated thin track record as equivalent to a confirmed weakness rather than as its own, less severe category of uncertainty.

Gate: if two products in the same scoring batch land on the same Universal Core score via different reasoning, stop and explicitly justify the coincidence or correct one of them. A shared number from different reasoning paths is itself a signal to re-check, not a neutral fact to let pass.

Step 4 — Universal Checks: Decide Scope Before Scoring Severity

For Concentrated Control Risk specifically, in any multi-product scoring batch, answer this question first, in writing, before assigning any deduction:

“Does the governance/admin structure being scored have demonstrated authority over this specific product's own contracts, or only general/nominal authority over the brand's ecosystem as a whole?”

Answer	Rule
Demonstrated authority over this product specifically (a real incident, exercised here)	Score at full weight for the match status found (e.g., SIMILAR MATCH = 50% of the universal check's ceiling)
General/nominal authority only, no product-specific demonstrated incident	Score at half the full-weight deduction for the same match status — the structure is real and relevant, but unproven at this specific product
No authority at all over this product	NOT PRESENT — 0 deduction

***The specific error this gate catches:** an earlier pass applied the identical full deduction to all five Frax products under one governance structure, even though the only demonstrated incident (RedemptionQueueV2) occurred in one product specifically (frxUSD) and one closely related one (Bridge/OFT). The other three products received no individual scrutiny before being assigned the same number.*

***Gate:** never apply a universal check's deduction identically across multiple products in one batch without first answering the authority-scope question above, in writing, per product.*

Step 5 — Arithmetic Verification (Independent of the Writing Process)

After every score is drafted, recompute every final total **independently** — using a calculator or a separate script, not by re-reading the prose. Specifically:

1. Sum every category table's individual pattern deductions and confirm it equals the stated category total.
2. Subtract every universal check deduction from the gross score and confirm it equals the stated final score.
3. If an average across multiple products is presented, recompute the average independently from the individual final scores — do not trust a previously-typed average.
4. For SIMILAR MATCH values (50% of a pattern's listed weight), explicitly compute the halved value and check it lands on a clean 0.5 increment; if not, apply the stated rounding rule (round to nearest 0.5, ties round toward the larger deduction) and show both the raw and rounded value.

***The specific error this gate catches:** in one published pass, two final totals (Fraxlend, sfrxETH) were typed as values one full point lower than what their own listed components actually summed to — a transcription error that a single independent recomputation catches immediately, and that careful prose-reading did not catch.*

***Gate:** do not present any final score, category total, or average without having performed this independent recomputation in the same response. Showing the recomputation's output (even briefly) is itself part of the gate — a silent mental check is not sufficient, because it is exactly what failed previously.*

Step 6 — Visual / Rendering Verification

After building any PDF, render it to an image and view it before delivering. Check specifically for: column headers wrapping awkwardly, tables overflowing page boundaries, and — critically — that the numbers visible in the rendered table match the numbers just verified independently in Step 5. A rendering bug that silently changes a displayed number is as serious as an arithmetic error and is only caught by actually looking at the output, not by trusting the code that generated it.

Step 7 — Cross-Product Consistency Pass (Multi-Product Only)

Once every product in a batch has a draft score, look at all of them together in one table before delivering any of them. Ask explicitly: does the relative ordering make sense given what was actually found? A product with zero findings should not score at or below a product with a real disclosed gap. A product with a directly demonstrated incident should not score the same as one with only general, nominal exposure to the same risk. If the ordering doesn't make sense, the error is more likely in the calibration than in the individual research — revisit Step 3 or Step 4 before re-publishing.

v2.2 Gap Reconciliation — Resolved

The v2.1 research basis identified four real gaps, assigned to a v2.2 that was designed but never built. Each is resolved here individually, using the same redundancy check applied during the v2.1 Systemic Penalties reconciliation — checking whether the gap already has a home in this methodology's eight category tables or universal checks before building anything new.

v2.2 Proposal	Resolution
Key Management (+2 pts)	RETIRED AS REDUNDANT. Its own validating case (Radiant Capital, \$50–53M, Oct 2024) is the exact same incident already validated — independently, twice — by Bridge Pattern 5 (Signing-Interface Spoofing), which carries real weight (-5 of Bridge's -15 ceiling). Building a separate Active sub-component for the same incident would double-count it.
Governance Attack Resistance (+2 pts)	RETIRED AS REDUNDANT. Its validating case (Beanstalk, \$181M, 2022, flash-loan-funded governance takeover) asks the same underlying question as Concentrated Control Risk: how much capital or how few independent parties does it take to seize unilateral control? The mechanism (renting voting power via flash loan) is a variant on the same risk Concentrated Control Risk already checks, not a separate category.

v2.2 Proposal	Resolution
Economic Attack Resistance / Flash Loan Resistance (+3 pts)	RETIRED AS REDUNDANT, after checking applicability across all eight categories first. Flash loans are a real, direct mechanism in exactly three categories (DEX/AMM, Lending, Yield Aggregator) — and in all three, the mechanism is already fully priced into an existing, validated pattern (DEX/AMM P1 via KiloEx; Lending P2 and Yield Aggregator P2 via Cream Finance). Flash loans do not meaningfully apply to Bridge or RWA, and only weakly/theoretically to Stablecoin and Insurance — disqualifying it as a true universal check. Explicit cross-reference notes were added to the three affected patterns instead, clarifying that flash-loan funding should never be scored as an additional, separate finding on top of the pattern it funds.
Audit/Bounty Scope Coverage Penalty (-2 to -3 pts)	BUILT AS A NEW WATCH-ITEM, added to Universal Penalty Checks (see below). Genuinely new — no existing pattern checks whether deployed contracts are actually covered by a protocol's own audits or bounty program. Validated by three real, named cases (Cork Protocol \$12M, Abracadabra, GMX V1 \$42M).

Why Flash Loan Resistance Is Not a Universal Check

A universal check, by definition, must apply regardless of category — the same way every protocol has some dependency structure (Inherited Risk) and some governance structure (Concentrated Control Risk). Flash loan risk does not clear that bar: it is structurally inapplicable to Bridge (a same-block, single-chain loan cannot fund a cross-chain verification exploit) and to RWA (an on-chain instrument cannot affect off-chain custody or who holds a real-world price-admin key). Treating it as universal would have meant scoring a non-existent risk for two full categories. The correct fix was narrower: strengthen the three categories where the mechanism is real and already validated, rather than build a fourth universal line that doesn't actually apply everywhere it would be checked.

New Watch-Item: Audit/Bounty Scope Coverage

Added to Universal Penalty Checks as a watch-item, ceiling -2 (not the full -5 given to Inherited Risk and Concentrated Control Risk, reflecting its narrower, more procedural nature). Checks whether a protocol's actually-deployed contracts are fully covered by its claimed audits and bounty program, or whether legacy/deprecated contracts and newer deployments have quietly fallen outside scope.

Match Status	Criteria	Deduction
SIMILAR MATCH (ceiling)	Confirmed gap between deployed contracts and audited/bounty-covered contracts (e.g., a legacy version still live but excluded from the current audit or bounty scope)	-2

Match Status	Criteria	Deduction
NOT PRESENT	Audit and bounty scope explicitly confirmed to cover all currently deployed, fund-holding contracts	0

Validated by three real, named cases: Cork Protocol (\$12M, exploited contracts reportedly out of bounty scope), Abracadabra (deprecated CauldronV4 logic left unaudited for ~2 years while newer features kept getting reviewed), and GMX V1 (\$42M, legacy contracts possibly excluded from bounty scope). Cannot reach EXACT MATCH — this check is inherently about a disclosed gap in coverage, not a severity tier beyond that.

Universal Penalty Budget — Deliberately Expanded to -30

Two real findings, both surfaced during this same reconciliation pass, are resolved differently and it matters that they are not confused with each other. Flash Loan/Economic Attack Resistance was tested for universality and failed — it does not apply to Bridge or RWA, so it was retired rather than added, and the -25 ceiling correctly stayed unchanged for that decision. Supply Chain Risk was tested the same way and passed: a real, independently validated mechanism (Trust Wallet \$7M, Polymarket \$3.1M) that applies across all eight categories, including the two that disqualified Flash Loan Resistance. Because it is genuinely universal and genuinely new — not redundant with Inherited Risk or Concentrated Control Risk — it is added as a third universal check at the same -5 ceiling as the other two, rather than squeezed into the existing -25 by diluting two checks that are already independently evidenced at their current weights. The budget is now -15 category-specific + -5 Inherited Risk + -5 Concentrated Control Risk + -5 Supply Chain Risk = **-30**. This is a deliberate, evidenced expansion, not a process drift — contrast with the silent -25→-30 expansion attempted and reverted earlier in this same reconciliation, before Supply Chain Risk had been tested for universality at all.

Why This Matters

A scoring methodology's credibility rests on reproducibility: the same evidence, run through the same procedure, should produce the same number — regardless of who or what is doing the scoring. Mistakes caught by a person reviewing the output after the fact are still mistakes; the goal of this procedure is to move every check that catches a real error into a mandatory step that happens before publication, every time, not into a hope that someone notices.

Aave (Lending)

Universal Core (0–97)

More than 10 formal reviews since the V3 launch in 2022, from OpenZeppelin, Trail of Bits, SigmaPrime, Certora, and ABDK, continuing through June 2025 — including formal verification (Certora), the highest audit tier in this methodology. A \$2.8B Safety Module provides a real, pre-existing backstop mechanism. Launched 2020, largest DeFi lending protocol by TVL, multi-chain across 7+ networks. Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10) — see the Gross Score Methodology changelog.

Component	Score
Foundation (max 45)	43.5
Active (max 55)	46
Gross Score	89.5

Lending — Category Penalty

Pattern	Finding	Deduction
P1 — Collateral Concentration	SIMILAR MATCH (rsETH concentration with e-mode leverage; bridge dependency confirmed but Aave's own exposure check is one step removed from KelpDAO's direct finding)	-3.5
P2 — Exotic Token Integration	NOT PRESENT (no ERC-777/donation-manipulable collateral identified)	0
P3 — Curator/Allocator Risk	NOT APPLICABLE (Aave is a direct-market protocol, not a curated vault product)	0

Category total: -3.5 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	KelpDAO's own Bridge P1 finding (SIMILAR MATCH — 1-of-1 DVN, no backup verifier) passes through, capped at the Inherited Risk ceiling. Aave does not operate a bridge itself; this captures the rsETH collateral dependency specifically.	-2.5

Check	Finding	Deduction
Concentrated Control Risk	SIMILAR MATCH — the most severe powers (market pause via Protocol Emergency Guardian, proposal veto via Governance Emergency Guardian) are gated at 5-of-9 multisigs with named signers, reasonably distributed. However, Risk Stewards can adjust real risk parameters (LTV, liquidation thresholds, supply/borrow caps) under a 1-of-1 multisig — a single signer, though scoped to on-chain-validated bounds.	-2.5
Supply Chain Risk	SIMILAR MATCH — no confirmed frontend/release-pipeline compromise found. Aave's Immunefi bug bounty includes careful, explicit contract-inheritance scoping, but no explicit confirmation was found that the bounty's scope extends to CI/CD, build pipeline, or npm-dependency infrastructure specifically (contrast with Uniswap's explicit infrastructure-bounty scope). Scored conservatively given this gap in confirmed coverage, not an identified weakness.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — Aave's Immunefi program explicitly defines in-scope contract inheritance chains and explicitly excludes the OpenZeppelin base contract as a disclosed boundary, not an unaddressed gap. Real, careful, documented scoping confirmed.	0
FINAL SCORE		78.5 / 97

Aave's penalty is concentrated in two roughly equal lines — its own collateral-acceptance decision (rsETH/KelpDAO) and a single-signer parameter-adjustment role (Risk Stewards) — rather than any confirmed code-level flaw. Aave's own contracts were never compromised; both deductions reflect choices about what to accept and who controls specific levers, not discovered vulnerabilities. Originally 78.5/97 under the prior 20/10 audit/code split, revised to 81.0/97 under the corrected 18/12 split, and now 78.5/97 again under the complete v2.3 check set after adding Supply Chain Risk (-2.5, conservative given unconfirmed infrastructure-bounty scope) and Audit/Bounty Scope Coverage (0, confirmed clean). The coincidental return to 78.5 reflects two independent corrections roughly offsetting, not a lack of real change.

Aave V3 on Aptos (Lending — Move)

Scored separately from Aave's Ethereum deployment per this methodology's multi-product rule — a different codebase (complete Move rewrite, not a fork), different track record, and a materially different collateral set, even though governance is shared.

Universal Core (0–97)

Launched August 2025 — a complete Move rewrite, not a ported Solidity contract, audited prior to launch. Chainlink price feeds confirmed. Initial assets: APT, sUSDe, USDT, USDC. Under 12 months of operating history as of this assessment, with no incident found specific to the Aptos deployment itself. Foundation and Active scored conservatively relative to the Ethereum deployment, reflecting genuinely thinner track record rather than any confirmed weakness — the same calibration principle applied to Lido EarnUSD earlier in this project.

Component	Score
Foundation (max 45)	36.0
Active (max 55)	39.0
Gross Score	75.0

Lending — Category Penalty

Pattern	Finding	Deduction
P1 — Collateral Concentration	SIMILAR MATCH — sUSDe bridges onto Aptos via LayerZero's OFT standard, the same architecture already scored at Frax. Ethena (sUSDe's issuer) was directly implicated in the same April 2026 KelpDAO/rsETH incident central to this project: Ethena suspended its LayerZero OFT bridge, then explicitly extended that suspension citing “lack of a satisfactory root cause analysis of the rsETH incident,” before later upgrading its DVN verifier configuration from 2-of-2 to 4-of-4 across all chains. A real, confirmed dependency with a real, confirmed remediation — scored as SIMILAR MATCH, not EXACT, reflecting that Ethena's own post-incident hardening is more rigorous than what was found for KelpDAO's own bridge.	-3.5
P2 — Exotic Token Integration	NOT PRESENT — no donation-manipulable collateral identified; Move's resource model structurally resists the donation/balance-inflation mechanism this pattern checks for (see Lending reference file's Move-chain translation note).	0

Pattern	Finding	Deduction
P3 — Curator/Allocator Risk	NOT APPLICABLE — same single-pool, direct-market, DAO-governed model as the Ethereum deployment, not a curated vault product.	0

Category total: **-3.5 / -15**

Universal Checks

Check	Finding	Deduction
Inherited Risk	Not separately scored — the sUSDe/Ethena bridge dependency is the same single fact already scored at full weight under Lending P1 above. Applying both would double-count one fact under two labels, consistent with this methodology's established precedent (Drift, Stream Finance).	0
Concentrated Control Risk	SIMILAR MATCH — same Aave DAO and Risk Steward governance structure shared with the Ethereum deployment; the same 1-of-1 parameter-adjustment role applies here, not a separate, independent finding for this deployment specifically.	-2.5
Supply Chain Risk	SIMILAR MATCH — same Aave-wide release process and bug bounty program as the Ethereum deployment; no confirmed infrastructure-bounty scope specific to the Aptos deployment found, consistent with the Ethereum deployment's own finding.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — same Aave-wide Immunefi program with explicit, careful contract-inheritance scoping as the Ethereum deployment.	0
FINAL SCORE		66.5 / 97

This completes the Move-chain dry run begun earlier in this project. Two real findings stand out. First, sUSDe's bridge dependency connects this deployment to the same rsETH/KelpDAO root incident already scored at Aave's Ethereum deployment and Lido's EarnETH — the same systemic event surfacing a third time across this project's scoring work, this time with a confirmed remediation response attached. Second, Move's resource model genuinely clears Pattern 2 on real, independently-confirmed structural grounds, not by assumption — the lower score here reflects thinner track record and a real bridge dependency, not any weakness in the Move rewrite itself.

Uniswap (DEX/AMM)

Universal Core (0–97)

Among the deepest audit records in this entire project: nine independent audits for V4 alone (OpenZeppelin, Spearbit, Certora, Trail of Bits, ABDK, Pashov), plus formal verification and the largest bug bounty in DeFi history (\$15.5M). V2 and V3 processed 465 million swaps and \$2.75 trillion in volume with zero confirmed hacks. No admin-key or small-multisig backdoor found — governance runs through pure on-chain token-weighted voting. Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10).

Component	Score
Foundation (max 45)	45
Active (max 55)	48
Gross Score	93

DEX/AMM — Category Penalty

Pattern	Finding	Deduction
P1 — Spot-Price-Only Pricing	NOT PRESENT (V3's TWAP oracle is an industry-standard reference implementation; audited, time-tested across hundreds of millions of swaps)	0
P2 — Pool Ratio Distortion	NOT PRESENT (no confirmed core-protocol incident of this type found)	0

Category total: 0 / -15

Disclosed, Unscored Risk Factor

V4 Hooks architecture: hooks let third-party developers inject custom logic into a pool's lifecycle, dramatically expanding the potential attack surface — a single misconfigured or malicious hook can lead to losses, denial-of-service, or pool manipulation. This is a real, disclosed architectural risk specific to V4's design, distinct from the core protocol (which itself remains well-audited). This does not fit cleanly into either existing DEX/AMM pattern — it is not a core-pricing flaw — and has no defined match-status trigger in this methodology yet. Noted here as a real, disclosed risk factor, not a deduction, consistent with how Lido's validator concentration was handled.

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified — no confirmed dependency on a separate protocol carrying an unresolved finding was found for Uniswap's core contracts.	0
Concentrated Control Risk	SIMILAR MATCH — no admin multisig or small-signer backdoor found; governance runs through pure on-chain token-weighted voting with a 0.25% proposal threshold, 7-day voting period, 4% quorum (40M UNI), and a 2–30 day timelock scaled to severity. The one narrow exception: a Guardian role can unilaterally cancel a proposal if the proposer's delegate balance drops below threshold — a specific safety valve, not a general veto. This is the most decentralized governance structure found in this project; scored SIMILAR MATCH rather than NOT PRESENT only because large-holder/delegate concentration could theoretically meet quorum without broad participation.	-2.5
Supply Chain Risk	NOT PRESENT — Uniswap's Cantina bug bounty explicitly defines infrastructure findings as in-scope, naming CI/CD pipelines, GitHub Actions, build systems, NPM packages, dependency confusion/namespace takeover, and malicious package injection via misconfigured publishing or missing lockfile controls. The clearest, most explicit real disclosure of this mechanism found for any protocol scored in this project. No confirmed incident.	0
Audit/Bounty Scope Coverage	NOT PRESENT — bounty scope explicitly limited to deployed contracts at named deployment addresses, with pre-production contracts (e.g., UniswapX's v4 Reactor) explicitly and proactively flagged as out-of-scope rather than silently excluded.	0
FINAL SCORE		90.5 / 97

Uniswap's score is the highest in this project, driven by a genuinely rare combination: a clean, multi-hundred-million-transaction track record with zero confirmed core-protocol hacks, one of the deepest audit histories found anywhere, and a governance structure with no small-multisig or admin-key shortcut. Its one deduction reflects token-concentration risk inherent to any token-weighted voting system, not a discovered flaw. Under the complete v2.3 check set, Uniswap is also the cleanest result found on Supply Chain Risk and Audit/Bounty Scope Coverage — its own bug bounty explicitly, proactively names infrastructure and dependency-supply-chain vectors as in scope, the clearest disclosure of this kind found for any protocol in this project. The score remains 90.5/97, unchanged by adding these two checks, because both came back genuinely clean rather than merely unverified.

Drift Protocol (Derivatives — Solana)

Universal Core (0–97)

Two real, named audits (Trail of Bits, 2022; ClawSecure, February 2026) — both confirmed to have cleared Drift's core contracts; the April 2026 exploit was not a code vulnerability and neither audit could reasonably have been expected to catch it. Launched 2021, pivoted to the current hybrid JIT/DLOB/AMM architecture in 2022 (Drift v2). Dominant Solana perpetuals exchange, ~\$400M open interest pre-incident. Track Record is heavily penalized for the real, dollar-quantified \$285M exploit — the protocol's own code was not compromised, but the real-world outcome for users was severe regardless of root cause attribution.

Component	Score
Foundation (max 45)	34
Active (max 55)	20
Gross Score	54

Derivatives — Category Penalty

Pattern	Finding	Deduction
P1 — Leverage/Liquidity Mismatch	NOT PRESENT (partial liquidation with throttled, multi-slot pacing; documented insurance fund per-asset, covering spot in full and perps up to a set limit; not implicated in the actual exploit)	0
P2 — Oracle/Mark Price Latency	NOT PRESENT (dual independent oracle sources — Pyth + Switchboard — with an explicit extreme-oracle-error circuit breaker that pauses fills/liquidations/funding; not implicated in the actual exploit, which used a privileged admin override to bypass normal collateral listing, not a price-feed weakness)	0
P3 — Binary Settlement Risk	NOT APPLICABLE (no evidence Drift operates binary/prediction-style settlement markets)	0

Category total: **0 / -15**

Why the category total is 0 despite a \$285M loss: Drift's actual leverage, liquidation, and oracle design — the three things this category table checks — are real, documented, and were not the attack vector. The exploit bypassed all of it through a privileged admin override. This is precisely why Universal Core and Concentrated Control Risk exist as separate lines from the category table: a protocol can have excellent category-specific design and still fail catastrophically through a governance/access-control failure that no category-specific pattern is built to catch.

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified — the malicious collateral asset (CarbonVote Token) was fabricated by the attacker using compromised admin access, not a genuine third-party protocol dependency Drift chose to integrate.	0
Concentrated Control Risk	EXACT MATCH — Security Council operated as a 2-of-5 multisig (40% threshold, below this methodology's 50% floor) with a 0-second timelock following a March 27, 2026 migration. Mechanism existed, power was verifiably concentrated below the floor, and there was no friction whatsoever — the admin transfer was proposed and executed one second apart, in the same block window. A real, demonstrated severe unilateral action, not a theoretical risk.	-5

Note on Supply Chain Risk (not applied): the attackers did compromise individual Drift contributors' personal devices via malware (a fake VS Code extension, a fake TestFlight app) to obtain signing credentials. This was considered against the Supply Chain Risk check and rejected as a genuine match — that check is specifically about a protocol's production frontend, browser extension, or release pipeline reaching ordinary end users, not an attacker obtaining an individual signer's credentials through targeted malware. The latter is conceptually closer to Bridge Pattern 5 (Signing-Interface Spoofing), generalized beyond the Bridge category, and is already fully captured by the Concentrated Control Risk finding above. Applying both would double-count the same incident under two labels.

FINAL SCORE

49.0 / 97

Drift's score is dominated by two real, distinct findings, not one: a heavily penalized Track Record (the \$285M loss itself, regardless of root cause) and a full Concentrated Control Risk deduction (the governance structure that made the loss possible). Its category-specific design — leverage limits, dual oracles, partial liquidation, a real insurance fund — was sound and uninvolved in the exploit, which is why the Derivatives category total is 0. This is a useful, real-world illustration of why this methodology separates category-specific design from universal governance risk: a protocol can score perfectly on one and still fail completely through the other.

Stream Finance (Stablecoin — xUSD)

Universal Core (0–97)

No named, verifiable audit firm identified despite vague public claims that “security audits found no flaws” — an unverifiable claim is scored at the floor, not given benefit of the doubt. No Proof of Reserves, no transparency dashboard (only an informal Debank bundle link). No multisig or on-chain governance structure of any kind — control of the protocol passed via an off-chain handshake agreement (January 2025) granting one individual “complete control... including all on-chain transactions, off-chain business protocols, and user deposit management,” with no custody segregation. Launched early 2024, operating under 24 months before total collapse.

Component	Score
Foundation (max 45)	12.5
Active (max 55)	2.0
Gross Score	14.5

Stablecoin — Category Penalty

Pattern	Finding	Deduction
P1 — Mint Authority Control	EXACT MATCH (a single individual held complete, unconstrained control over xUSD's backing and issuance via an off-chain agreement with no multisig, no custody segregation, no on-chain enforcement of any kind; confirmed misappropriation of \$93M in backing assets)	-8
P2 — Collateral Liquidity Depth	EXACT MATCH (confirmed ~\$170M in verifiable backing against \$530M+ in liabilities — 7.6x leverage against actual collateral — with redemptions frozen entirely once the shortfall became public)	-5.5
P3 (WATCH-ITEM) — Off-Chain Operational Dependency	SIMILAR MATCH (entire backing strategy delegated to an unnamed, unaudited “external fund manager” with no independent oversight — the watch-item’s defining scenario realized in full)	-0.75

Category total: -14.25 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	Not applicable — Stream is the source of contagion to other protocols (Elixir's deUSD, multiple Morpho/Euler curated vaults), not an inheritor of a separate protocol's unresolved finding.	0
Concentrated Control Risk	Not separately scored — the single fact underlying this check (one individual's total, unconstrained control via an off-chain agreement) is the exact same evidence already scored at full weight under Stablecoin P1 above. Applying both would double-count one fact under two labels, which this methodology's own precedent (established during the Drift Protocol score) explicitly avoids.	0
FINAL SCORE		0.25 / 97

Stream Finance is the lowest score in this project to date, and it is honestly earned rather than a methodology artifact: there is genuinely almost nothing on the record to credit. No verifiable audit, no governance structure of any kind, no transparency mechanism, and a confirmed total collapse driven by a single unconstrained individual. This is not primarily a curator-negligence story, despite public narratives that shifted blame there — Morpho and Euler's own curator permission boundaries (set risk parameters, choose collateral) structurally prevented curators from directly transferring user funds; the actual mechanism was personal misappropriation by the one party Stream itself gave unconstrained control. This score should be read as a genuine floor case — useful precisely because it shows what near-total absence of every safeguard this methodology checks for actually produces.

Pendle V2 (Yield Aggregator / Yield Tokenization)

Scored against Pendle V2 — the core PT/YT yield-stripping product (~\$933M TVL). Boros (funding-rate derivatives, launched late 2025) is a distinct product on different contracts and would warrant a separate, Derivatives-category score; it is not included here.

Universal Core (0–97)

Multiple real, named audits: Ackee, Dedaub, Dingbats, top Code4rena wardens, ChainSecurity (V2 core and separately for Boros), and Least Authority — the broadest multi-firm audit coverage found outside Aave and Lido in this project. Core contract repository archived January 2026, signaling mature, finalized code. Launched October 2021 (V1) and V2 thereafter; 4+ years operating. No exploit of Pendle's own contracts found. The Penpie incident (\$27M, September 2024) was a reentrancy bug in Penpie's own contracts — a third-party yield optimizer built on top of Pendle. Penpie accepted all Pendle markets without validating whether they were legitimate, and Pendle's contracts themselves were never compromised. Pendle froze its own protocol voluntarily as a precaution and quickly resumed. This is explicitly the same Euler/Universal Core boundary this methodology has already established: the loss happened at a separate protocol using Pendle's permissionless infrastructure, not inside Pendle's contracts. \$250K Immunefi bug bounty confirmed active.

Component	Score
Foundation (max 45)	42.5
Active (max 55)	36.5
Gross Score	79.0

Yield Aggregator — Category Penalty

Pattern	Finding	Deduction
P1 — Deprecated Strategy / Code	NOT PRESENT — core contract repository archived January 2026, explicitly signaling finalized, stable code with no legacy strategies still running on unreviewed contracts. No deprecated, still-live code identified.	0
P2 — Donation-Manipulable Vault Share Price	CANNOT DETERMINE — Pendle V2's PT/YT mechanism uses a custom time-decay AMM with a specialized curve design, not a simple balanceOf()-based share-price calculation this pattern was built around. ChainSecurity's audit explicitly notes the mathematical complexity of the margin/pricing logic. The architecture is structurally different from the Cream Finance or Yearn mechanisms this pattern validates against — not confirmed safe, but not a direct match to the validated mechanism either.	0 (unverified)

Category total: **0 / -15**

The CANNOT DETERMINE on Pattern 2 reflects genuine uncertainty about how Pendle's novel AMM mechanism interacts with the donation vector, not a clean clearance. A full assessment would require reading the actual share-price calculation logic in the SY wrapper contracts against the Pattern 2 criteria — which as a data aggregator this methodology does not perform independently.

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified — no specific dependency on a separate protocol carrying an unresolved finding. The Penpie incident was Penpie's own code; it is not an external protocol whose risk passes through to Pendle.	0
Concentrated Control Risk	SIMILAR MATCH — the SPENDLE tokenomics migration (January 2026) involves multisig-controlled parameter changes during transition; Pendle's admin addresses control key market parameters. No demonstrated unilateral adverse action found, but disclosure of the admin key structure is less complete than Aave or Lido's.	-2.5
Supply Chain Risk	SIMILAR MATCH — \$250K Immunefi bounty is real and active but no explicit confirmation found that the bounty scope extends to CI/CD, build pipeline, or npm-dependency infrastructure specifically. No confirmed incident.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — all audited contracts are explicitly public on GitHub; contract addresses are documented per chain; Boros audited separately by ChainSecurity. No evidence of deployed contracts outside confirmed audit scope.	0
FINAL SCORE		74.0 / 97

Pendle's score reflects a genuine combination of strong audit history (broadest multi-firm coverage of any Yield Aggregator scored in this project), a clean 4-year track record in its own contracts, and two real limitations: a modest bug bounty (\$250K against \$933M TVL) and a mathematically novel AMM mechanism that this methodology cannot definitively clear on Pattern 2 without deeper code inspection. The Penpie incident is correctly excluded — it was Penpie's own reentrancy bug, not Pendle's — but it remains a real illustration of the inherited risk users take when third-party products build permissionlessly on top of a protocol that was itself uninvolved.

Resolv Labs — USR (Stablecoin — Incident Recovery)

Status at scoring: minting and redemption paused, recovery framework published May 2026, Vault Street institutional product announced. USR peg broken, partially recovering. Scored as a live but impaired protocol, not a shut-down one.

Universal Core (0–97)

14 audit engagements from five firms — real, named, broad coverage. None identified the SERVICE_ROLE vulnerability because it was entirely off-chain (AWS KMS); the on-chain contracts themselves passed every audit as designed. This is a second, confirmed case of the same Euler boundary this methodology already documents: audits cannot catch what they cannot see, and the flaw here was in the off-chain trust architecture, not Solidity. \$500K Immunefi bounty confirmed active — real but did not surface the vector. Hypernative monitoring partnership existed; the protocol was not paused for three hours post-exploit (pause itself required a multisig). TVL declined from \$684M peak to ~\$95M pre-exploit. Launched 2023 (Abu Dhabi-based); raised \$10M seed led by Cyber.Fund and Maven11, with Coinbase Ventures, Animoca, Arrington Capital participating.

Component	Score
Foundation (max 45)	22.9
Active (max 55)	11.0
Gross Score	33.9

Stablecoin — Category Penalty

Pattern	Finding	Deduction
P1 — Mint Authority Control	EXACT MATCH — SERVICE_ROLE was a single externally owned account with unlimited, unchecked minting authority stored in AWS KMS. No multisig, no on-chain oracle check, no maximum mint limit, no per-epoch cap. The attacker deposited \$100K USDC and received 50M USR — 500x the expected amount — because nothing in the on-chain contract validated the ratio. Confirmed as the root cause by multiple independent analyses.	-8
P2 — Collateral Liquidity Depth	EXACT MATCH — USR crashed to \$0.025 (\$0.02 low) upon the 80M unbacked USR flood. Redemptions frozen. The collateral pool technically remained intact (the attacker converted minted USR to ETH, not the reserve directly) but USR holders could not redeem at par — the functional definition of a collateral liquidity failure.	-5.5

Pattern	Finding	Deduction
P3 (WATCH-ITEM) — Off-Chain Operational Dependency	SIMILAR MATCH (ceiling) — the entire minting flow delegated authority to an off-chain signing service with no on-chain backstop. The watch-item's defining scenario, realized in full.	-0.75

Category total: **-14.25 / -15**

Universal Checks

Check	Finding	Deduction
Inherited Risk	Not applicable — Resolv is the source of contagion (15+ Morpho vaults, Stream Finance's \$17M exposure), not an inheritor of a separate protocol's unresolved finding.	0
Concentrated Control Risk	Not separately scored — the single EOA finding is the same underlying fact already scored at full weight under Stablecoin P1. Applying both would double-count one fact under two labels, consistent with this project's established precedent (Drift, Stream Finance).	0
Supply Chain Risk	SIMILAR MATCH — AWS KMS was the third-party vendor whose compromise provided the attack path. Closer to this check's definition than Drift's contributor-device case (the vendor-managed infrastructure directly enabled the minting exploit) though distinct from the frontend/release-pipeline mechanism that originally validated this check.	-2.5
Audit/Bounty Scope Coverage	EXACT MATCH (watch-item ceiling applied: -2.0) — 14 audits across five firms explicitly did not cover the off-chain SERVICE_ROLE key management. The minting contract's security depended entirely on the off-chain key never being compromised; that assumption was outside every audit's scope. Steakhouse Financial flagged the operational risk five days before the attack in a published report — confirming the gap was identifiable, just not by the audits themselves.	-2.0
FINAL SCORE		15.1 / 97

Resolv scores above Stream Finance (0.25) because it had genuine, named auditors and a real, meaningful bug bounty — both absent from Stream. But 14 audits finding nothing and a \$500K bounty finding nothing ultimately did not prevent a near-total peg collapse, because the real vulnerability was off-chain and invisible to every on-chain review. This is the single clearest case in this project of why this methodology's own Audit/Bounty Scope Coverage check exists: the gap was real, documented, and in hindsight identifiable — Steakhouse Financial flagged it five days before the attack.

Curve Finance (DEX/AMM — Stablecoin/Correlated Assets)

Universal Core (0–97)

Launched 2020; 5+ years operating; the dominant stablecoin/correlated-asset AMM in DeFi. Multiple named audits across a public audit index (Trail of Bits, ChainSecurity, Quantstamp historically). The July 30, 2023 exploit (\$52–70M) was a Vyper compiler bug (versions 0.2.15, 0.2.16, 0.3.0) causing a malfunctioning reentrancy lock — critically, this was a language-level compiler defect, not an error in Curve’s own business logic or math. Affected pools have since migrated; compensation of \$49M in CRV was approved and distributed via community fund governance. This is the same Universal Core / tooling-defect boundary established for Euler and Cetus: this methodology’s pattern checks would not have caught it, and it does not map to DEX/AMM Pattern 1 or 2. It does, however, materially affect Track Record.

Component	Score
Foundation (max 45)	39.0
Active (max 55)	46.0
Gross Score	85.0

DEX/AMM — Category Penalty

Pattern	Finding	Deduction
P1 — Spot-Price-Only Pricing	NOT PRESENT — Curve’s EMA (exponential moving average) oracle is the reference example for clearing this pattern across the entire project. Validated during the original dry-run testing against this protocol that produced the Harvest Finance downstream-integrator distinction now built into Pattern 1’s definition.	0
P2 — Pool Ratio Distortion	NOT PRESENT — no auxiliary burn/fee mechanism that could be used to distort pool ratio without actual liquidity found.	0

Category total: **0 / -15**

The 2023 Vyper exploit does not map to either DEX/AMM pattern. It is correctly scored as a code/tooling incident that affects Track Record and Active Security Infrastructure, not as a category-pattern finding.

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified — no confirmed external protocol dependency carrying an unresolved finding.	0
Concentrated Control Risk	SIMILAR MATCH — veCRV concentration: Convex Finance controls a large share of veCRV voting power, meaning a material fraction of Curve governance is effectively delegated to a single secondary protocol. This is a real, disclosed, structural concentration, though it has been stable and non-adversarial for years.	-2.5
Supply Chain Risk	NOT PRESENT — the 2023 Vyper exploit was a compiler vulnerability, not a frontend/build-pipeline/vendor compromise of the kind this check targets. No confirmed supply-chain incident against Curve's own release infrastructure found. Audit/bounty scope explicitly covers deployed contracts.	0
Audit/Bounty Scope Coverage	NOT PRESENT — public audit index maintained; affected pools from 2023 have been migrated and new pools audited. Post-incident, Curve's transparency around affected vs. unaffected contracts was exemplary.	0
FINAL SCORE		82.5 / 97

Curve's score reflects a genuinely strong protocol that absorbed a real, serious incident (the Vyper exploit, \$52–70M) and responded with compensations, migration, and transparency — and continues to operate as one of DeFi's most critical liquidity venues. Its category penalty is 0, correctly: neither DEX/AMM pattern applied to the actual incident mechanism. The one deduction is veCRV concentration through Convex — real, disclosed, but long-stable. The Vyper incident's real impact is captured entirely through Track Record and Active Security scores, not through any category pattern, which is the correct way to score a tooling/compiler vulnerability that this methodology explicitly acknowledges it cannot detect in advance.

Morpho Blue (Lending — Immutable Isolated Markets)

Scored as Morpho Blue (the core 650-line immutable primitive) only. Morpho Vaults (the curator allocation layer) is a materially distinct product with its own risk profile and would warrant a separate score under this methodology's multi-product rule.

Universal Core (0–97)

Formal verification applied to core contracts, alongside multiple professional audits (ChainSecurity for Vault V2 confirmed; Blue docs cite mutation testing, fuzzing, peer reviews). Immutable core: once deployed, no market's parameters can be changed by governance or the team — the most complete access-control posture found for any protocol in this project. Launched 2023 (Blue), building on Morpho Optimizer (2022). No confirmed exploit of Morpho Blue's own contracts. During the KelpDAO April 2026 event (\$292M), Morpho's total exposure was \$1M across two isolated markets — real, live proof that the isolation design functions under stress. \$7.2B TVL as of May 2026 (second-largest DeFi lender behind Aave); institutional integrations include Coinbase (\$2.17B+ USDC routed), Apollo Global (\$940B AUM cooperation agreement), Bitwise, and the Ethereum Foundation.

Component	Score
Foundation (max 45)	44.0
Active (max 55)	50.0
Gross Score	94.0

Lending — Category Penalty

Pattern	Finding	Deduction
P1 — Collateral Concentration	NOT PRESENT — isolated market design ensures one market's collateral cannot contaminate another. Each market sets its own collateral, oracle, and parameters at creation and they are immutable thereafter. KelpDAO event: \$1M total exposure across two isolated markets — empirical confirmation the design held.	0
P2 — Exotic Token Integration	SIMILAR MATCH — Morpho Blue is explicitly permissionless: any token can be set as collateral by any market creator with no on-chain gate. The design deliberately accepts ERC-777, rebasing, or any other non-standard token as collateral in individual markets, relying on curator judgment (in Vaults) or direct depositor judgment (in Blue) to avoid poor collateral choices. The mechanism this pattern checks for is technically present; the design's response is to isolate rather than prohibit.	-2.25

Pattern	Finding	Deduction
P3 — Curator/Allocator Risk	NOT APPLICABLE at the Blue level — Morpho Blue does not decide curator allocation. The curator layer is the Vaults product, which is separately designed and not scored here.	0

Category total: **-2.25 / -15**

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified at the Blue level — each market sets its own oracle and collateral independently; no shared dependency on an external protocol with an unresolved finding.	0
Concentrated Control Risk	SIMILAR MATCH at reduced weight — 5/9 governance multisig for protocol-level actions; however, Morpho Blue's immutable design means the multisig cannot modify any deployed market's parameters, dramatically limiting the surface area for a unilateral harmful action. Scored at half the standard -2.5.	-1.25
Supply Chain Risk	SIMILAR MATCH — institutional-grade protocol with strong security practices, but no explicit confirmation found that the bounty scope extends to CI/CD, build pipeline, or npm-dependency infrastructure specifically.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — formal verification, public audit index, and per-module documentation all confirmed. Audit coverage explicitly includes Blue and Vaults as separate products.	0
FINAL SCORE		88.0 / 97

Morpho Blue is the second-highest scoring single protocol in this project (88.0/97), behind only Uniswap (90.5/97). Its score reflects three genuinely unusual properties: formal verification applied to the core contract, an immutable design that eliminates the governance attack surface almost entirely, and empirical proof under stress that the isolation design works (the KelpDAO event, where \$292M moved through Aave while Morpho's total exposure was \$1M). Its only real deductions are the permissionless collateral design (which is intentional, not a gap) and the standard SIMILAR MATCH on Supply Chain Risk that applied to most protocols in this project. Morpho Vaults, the curator allocation layer, is a separate product with meaningfully higher Lending P3 exposure — it should not be assumed to score the same as Blue.

Frax Ecosystem

Frax is not one protocol — it is five materially distinct products under one brand. Per this methodology's multi-product rule, each is scored independently, with its own Universal Core (audit history, track record) and its own category-specific penalty. This summary presents all five together with an average; **the average is a convenience view, not a substitute for the individual scores** — a single number cannot represent five structurally different risk profiles.

Individual Product Scores

Product	Category	Final Score
Fraxswap	DEX/AMM	73.25 / 97
Fraxlend	Lending	62.75 / 97
sfrxETH	Yield Aggregator	68.25 / 97
frxUSD	Stablecoin	57.26 / 97
Frax Cross-Chain / OFT	Bridge	41.0 / 97
Average	—	60.5 / 97

Reading This Summary Correctly

The 60.5/97 average should not be read as “Frax's score.” A user depositing into sfrxETH (68.25/97) is not exposed to frxUSD's institutional-custodian concentration risk, and a user holding frxUSD (57.26/97) is not exposed to Fraxlend's permissionless-market token risk. Averaging is useful only as a single-glance ecosystem health indicator — anyone making an actual deposit decision should reference the specific product's own scorecard.

Concentrated Control Risk is scored per product, scaled by demonstrated reach, not as a flat protocol-wide tax. The 3-of-5 Comptroller/Timelock multisig has general authority across the Frax ecosystem, but the one real demonstrated incident of unilateral action (the undisclosed RedemptionQueueV2 patch) occurred specifically in frxUSD's redemption mechanism. frxUSD and the Bridge/OFT (which frxUSD depends on most heavily) carry the full -2.5 direct-evidence deduction; Fraxswap, Fraxlend, and sfrxETH — where the same multisig has general but not specifically demonstrated authority — carry a lighter -1.25 indirect-authority deduction. This avoids both extremes: treating one governance structure as five independent risks, and treating one demonstrated incident as if it proves equal risk everywhere the same signers have nominal authority.

Supply Chain Risk is the one finding genuinely identical across all five products. Frax's own bug bounty terms explicitly state that coverage “does not cover any front-end bugs/visual bugs or any type of server-side code of any web application” — smart contracts only. This is a real, disclosed scope exclusion, not an unconfirmed gap, and it applies uniformly because the bounty terms themselves draw no distinction between products. No realized incident was found at any product as a result of this gap.

Lowest-scoring product and why: Frax's cross-chain/OFT infrastructure (41.0/97) scores lowest — driven primarily by two CANNOT DETERMINE findings (undisclosed DVN configuration, no documented failover practice) compounding with the shared governance finding, not by a confirmed exploit. This should be read as the least-verified product, not necessarily the most dangerous one — the distinction matters and is preserved deliberately rather than collapsed into one severity signal.

Fraxswap (DEX/AMM)

Universal Core (0–97)

Audited once by Trail of Bits (August 2022) — a top-tier firm, but a single audit now roughly four years old with no dedicated Fraxswap-specific re-audit found since. TWAMM design (time-weighted average market maker) is architecturally distinctive and has operated without a publicly confirmed exploit. Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10) — see the Gross Score Methodology changelog.

Component	Score
Foundation (max 45)	35
Active (max 55)	42
Gross Score	77

DEX/AMM — Category Penalty

Pattern	Finding	Deduction
P1 — Spot-Price-Only Pricing	NOT PRESENT (TWAP-derived pricing combined with Chainlink feed; Certora BMM audit Oct 2024 confirms manipulation resistance)	0
P2 — Pool Ratio Distortion	NOT PRESENT (FXS buyback/burn is governance-driven, not externally triggerable)	0

Category total: 0 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	None identified — Fraxswap does not depend on a third-party protocol carrying an unresolved finding.	0
Concentrated Control Risk	SIMILAR MATCH at reduced weight — the 3-of-5 Comptroller/Timelock multisig has general, ecosystem-wide authority, but the one demonstrated incident of unilateral action (RedemptionQueueV2) occurred in frxUSD's redemption mechanism, not Fraxswap's contracts. No evidence this multisig has exercised authority over Fraxswap specifically. Scored at half the direct-evidence weight applied to frxUSD and Bridge.	-1.25

Check	Finding	Deduction
Supply Chain Risk	SIMILAR MATCH — Frax's own bug bounty terms explicitly state coverage does not extend to “any front-end bugs/visual bugs or any type of server-side code of any web application” — smart-contract-only scope, applied identically across all five Frax products. This is a real, disclosed coverage gap, not an unconfirmed one: no independent bounty-driven scrutiny of frontend/release infrastructure exists. No realized incident found.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — the bounty explicitly defines smart-contract scope as “all smart contracts deployed by the Frax Deployer addresses including Fraxswap AMM, Fraxlend, and frxETH” — no evidence of contracts deployed outside this stated scope.	0
FINAL SCORE		73.25 / 97

Fraxswap's only real gap is audit recency, not a security finding — its pricing and pool-ratio design both clear cleanly on real evidence. Its Concentrated Control deduction is lighter than frxUSD's or the Bridge's, reflecting that the demonstrated governance-concentration incident has no known connection to Fraxswap's own contracts specifically. Recalibrated under the corrected 18/12 Audit/Code split.

Fraxlend (Lending)

Universal Core (0–97)

Audited twice by Trail of Bits (November 2022, January 2023) — two engagements with the same top-tier firm, reasonably recent. Permissionless, isolated-market architecture (similar to Morpho Blue) means risk varies by individual market, not uniformly across the protocol.

Component	Score
Foundation (max 45)	33
Active (max 55)	36
Gross Score	69

Lending — Category Penalty

Pattern	Finding	Deduction
P1 — Collateral Concentration	NOT PRESENT (native markets: frxETH/sfrxETH backed by Beacon Chain staking, not bridge-dependent) / CANNOT DETERMINE (permissionless third-party markets, no full inventory available)	0
P2 — Exotic Token Integration	SIMILAR MATCH (no restriction on ERC-777/rebasing tokens in permissionless markets; Code4rena Aug 2022 found a front-running issue via salt reuse)	-2.5
P3 — Curator/Allocator Risk	NOT APPLICABLE (direct-market protocol, not a curated vault product)	0

Category total: -2.5 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	None directly — native Fraxlend markets are not bridge-dependent; permissionless third-party markets are CANNOT DETERMINE, not scored as a finding.	0

Check	Finding	Deduction
Concentrated Control Risk	SIMILAR MATCH at reduced weight — same general ecosystem authority as Fraxswap; no evidence the demonstrated RedemptionQueueV2 incident extended to Fraxlend's own markets. Scored at half the direct-evidence weight applied to frxUSD and Bridge.	-1.25
Supply Chain Risk	SIMILAR MATCH — same explicit, disclosed coverage gap as Fraxswap: Frax's bug bounty terms explicitly exclude all front-end and server-side code, applying identically across products. No realized incident found.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — Fraxlend is explicitly named in the bounty's stated smart-contract scope.	0
FINAL SCORE		62.75 / 97

Fraxlend's deduction comes entirely from its permissionless design accepting unrestricted token types in third-party-created markets — a real, disclosed structural choice, not a discovered bug. Native markets (frxETH/sfrxETH) carry no penalty. Recalibrated under the corrected 18/12 Audit/Code split; its real disclosed structural gap weighs into Code & Contract History rather than Audit & Verification, since the underlying audits themselves were clean.

sfrxETH (Yield Aggregator / Liquid Staking)

Universal Core (0–97)

Audited by Code4rena (September 2022) and Frax Security Cartel (March/April 2024) — two engagements, the more recent one within the last two years. Zero publicly confirmed slashing events to date. Checked against the corrected 18/12 Audit/Code split; its decayed audit score sits comfortably under both the old and new caps, so this product's gross score is unaffected by the change.

Component	Score
Foundation (max 45)	35
Active (max 55)	40
Gross Score	75

Yield Aggregator — Category Penalty

Pattern	Finding	Deduction
P1 — Deprecated Strategy Retirement	NOT PRESENT (no live deprecated vault versions holding user funds; Timelock + frxETH Treasury multisig documented for emergency pause)	0
P2 — Donation-Manipulable Share Price	SIMILAR MATCH (share price formula reads as a raw vault balance calculation; internal-ledger-vs-balanceOf distinction not independently verified)	-3

Category total: -3 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	None directly — sfrxETH wraps native Ethereum consensus-layer staking, not a third-party DeFi protocol.	0
Concentrated Control Risk	SIMILAR MATCH at reduced weight — same general ecosystem authority as Fraxswap; no evidence the demonstrated RedemptionQueueV2 incident extended to sfrxETH's own contracts. Scored at half the direct-evidence weight applied to frxUSD and Bridge.	-1.25

Check	Finding	Deduction
Supply Chain Risk	SIMILAR MATCH — same explicit, disclosed coverage gap as Fraxswap and Fraxlend: front-end and server-side code excluded from bounty scope. No realized incident found.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — frxETH/sfrxETH is explicitly named in the bounty's stated smart-contract scope.	0
FINAL SCORE		68.25 / 97

sfrxETH's emergency pause mechanism is real and documented, and the protocol has no deprecated-vault exposure. Its one deduction is an unverified implementation detail in the share-price formula, the same category of finding (and exact wording) validated independently at Beefy Finance.

frxUSD (Stablecoin)

Universal Core (0–97)

Most recent audit coverage of the Frax product suite: Certora (October 2024, via the BMM engagement), a formal-verification firm — the highest audit tier in this methodology. Institutional custodian model (BlackRock BUIDL, Superstate USTB, Securitize, Circle). Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10).

Component	Score
Foundation (max 45)	36.26
Active (max 55)	34
Gross Score	70.26

Stablecoin — Category Penalty

Pattern	Finding	Deduction
P1 — Mint Authority Control	SIMILAR MATCH (distributed per-custodian mint caps exist, but core team 3-of-5 multisig controls Comptroller/Timelock with admin override capability — confirmed exercised, see RedemptionQueueV2 incident)	-4
P2 — Collateral Liquidity Depth	SIMILAR MATCH (BUIDL+USTB >90% of backing; secondary exit liquidity concentrated in FRAX/sUSDS, not major settlement assets; redemption capacity under stress untested)	-3
P3 (WATCH-ITEM) — Off-Chain Operational Dependency	SIMILAR MATCH (>90% backing concentrated across two institutional custodians; no disclosed reserve fund for custodian disruption)	-1

Category total: -8 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	None directly — frxUSD's backing is RWA/custodian-based, not dependent on a separate DeFi protocol's unresolved finding.	0

Check	Finding	Deduction
Concentrated Control Risk	3-of-5 core team multisig controls Comptroller and Timelock; demonstrated unilateral, undisclosed action (RedemptionQueueV2 patch, Dec 2025, deployed without community disclosure, bytecode left out of sync with GitHub). SIMILAR MATCH at full direct-evidence weight — the demonstrated incident occurred specifically in frxUSD's redemption mechanism, unlike the other four products, which receive a lighter, indirect-authority weighting.	-2.5
Supply Chain Risk	SIMILAR MATCH — same explicit, disclosed coverage gap as the other Frax products: front-end and server-side code excluded from bounty scope. Notably, the one real demonstrated incident at frxUSD (RedemptionQueueV2) was itself a deployment that left bytecode out of sync with GitHub — a release-process gap, though already fully captured by the Concentrated Control Risk line above, not separately re-counted here.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — frxUSD's custodian contracts and redemption pathways are explicitly named and governed by individual Frax Improvement Proposals; no evidence of contracts deployed outside disclosed scope.	0
FINAL SCORE		57.26 / 97

frxUSD is the lowest-scoring product in the Frax ecosystem, and for a specific, traceable reason: it's the product where the demonstrated governance-concentration finding (the undisclosed RedemptionQueueV2 patch) most directly intersects with mint-authority and reserve-adequacy risk. This is the only Frax product carrying the full Concentrated Control Risk deduction. Recalibrated under the corrected 18/12 Audit/Code split; the formal-verification premium gives a modest boost to its Audit score, but this is outweighed by its real, validated category and governance findings.

Frax Cross-Chain (LayerZero OFT) (Bridge)

Universal Core (0–97)

No Frax-specific bridge audit identified separately from the broader protocol audit history; relies on LayerZero's underlying infrastructure. All Frax cross-chain assets (frxUSD, frxETH, FRAX, FXS) use the same OFT mechanism. Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10).

Component	Score
Foundation (max 45)	18.5
Active (max 55)	32
Gross Score	50.5

Bridge — Category Penalty

Pattern	Finding	Deduction
P1 — Verifier Independence	SIMILAR MATCH (Frax states DVNs are not Frax-operated, a positive signal, but actual DVN configuration/threshold is undisclosed for any Frax pathway)	-3
P2 — Failover Behavior	CANNOT DETERMINE (no public documentation on failover/degradation behavior found)	0 (disclosed unverified)
P3 — Key Custody	SIMILAR MATCH (OFT permissions: 3-of-6 multisig per chain, threshold disclosed, storage practices not; RedemptionQueueV2 confirms unilateral upgrade capability in practice)	-1.5
P5 — Signing-Interface Spoofing	CANNOT DETERMINE (no documented independent transaction-verification practice found for OFT permission signers)	0 (disclosed unverified)

Category total: -4.5 / -15

Universal Checks

Check	Finding	Deduction
Inherited Risk	None — this entry is the bridge itself; inherited risk does not apply to the source of the risk.	0

Check	Finding	Deduction
Concentrated Control Risk	3-of-5 core team multisig controls Comptroller/Timelock, with demonstrated unilateral action; the same governance structure controls bridge configuration changes. SIMILAR MATCH at full direct-evidence weight — frxUSD is the asset most exposed through this Bridge pathway, and the OFT permission structure (3-of-6 per chain) sits under the same authority that exercised unilateral action in the RedemptionQueueV2 incident.	-2.5
Supply Chain Risk	SIMILAR MATCH — same explicit, disclosed coverage gap: front-end and server-side code excluded from bounty scope. This is the product where the gap matters most, since cross-chain transfers depend heavily on an undisclosed DVN configuration in addition to the frontend exclusion (see Bridge P1/P2 above) — two real, compounding under-verification findings, not one.	-2.5
Audit/Bounty Scope Coverage	CANNOT DETERMINE — no public documentation found confirming whether OFT contracts across all chains are uniformly within the stated bounty scope, consistent with the broader documentation gaps already found in Bridge P2/P5.	0 (disclosed unverified)
FINAL SCORE		41.0 / 97

Frax's cross-chain infrastructure is the weakest-scoring product in the ecosystem — not because of a confirmed exploit, but because two of four Bridge patterns returned CANNOT DETERMINE (undisclosed DVN configuration, no documented failover practice) on top of a real, demonstrated Concentrated Control finding. This score should be read as 'meaningfully under-verified,' not 'meaningfully unsafe.'

Lido Core Staking (Liquid Staking (stETH/wstETH))

Universal Core (0–97)

Exceptionally deep audit transparency: 93 publicly published audit reports for Lido on Ethereum alone, plus formal verification by Runtime Verification on the Dual Governance mechanism — the highest audit tier in this methodology. Over 5 years securing up to \$38B in TVL with zero incidents resulting in monetary loss to core staking specifically. Non-custodial design; Immunefi bug bounty up to \$500K for critical findings. Recalibrated under the corrected 18/12 Audit/Code split (previously 20/10).

Component	Score
Foundation (max 45)	43.5
Active (max 55)	44
Gross Score	87.5

Category Note

Liquid Staking has no standalone category file — per the established rule, its real risks decompose into existing categories. Core Staking itself has no collateral/counterparty dependency of its own; no category penalty table applies.

Universal Checks

Check	Finding	Deduction
Inherited Risk	None — core staking (stETH/wstETH) was explicitly confirmed unaffected by the KelpDAO/rsETH incident, which was isolated to the separate EarnETH product. This is the cleanest possible Inherited Risk result: a real incident occurred elsewhere in the ecosystem and core staking was verifiably untouched, not merely unmentioned.	0
Concentrated Control Risk	SIMILAR MATCH — Dual Governance is a genuinely sophisticated mitigation: stETH holders can trigger a rage-quit/veto-signaling mechanism if LDO holders push a harmful change, with a 5-of-7 execution multisig explicitly designed as a one-off failsafe, not a standing power. This is core staking's own primary governance layer, so it applies at full weight here — unlike the Earn vaults, where the connection to this same governance structure is less direct. Credited as real design, but not yet tested under a real adversarial governance attack.	-2.5

Check	Finding	Deduction
Supply Chain Risk	SIMILAR MATCH — Lido's ImmuneFi bug bounty does cover "smart contracts and apps," with a dedicated severity scale for websites/apps requiring proof-of-concept, real disclosed coverage beyond Aave's silence. However, this confirms reactive web-bug coverage, not the specific proactive release-process safeguards (multi-party review, dependency pinning, build integrity monitoring) this check's NOT PRESENT bar requires. No confirmed incident found.	-2.5
Audit/Bounty Scope Coverage	NOT PRESENT — exceptionally granular, product-specific bounty scope found across multiple Lido programs (core protocol, Dual Governance, V3 stVaults), each independently maintained and updated; testnet contracts explicitly excluded from scope.	0
FINAL SCORE		82.5 / 97

Core staking is Lido's strongest product by a meaningful margin: a 5-year, \$38B-TVL track record with zero monetary losses, and a real, demonstrated separation from the EarnETH incident — not just an unscored absence of bad news, but an explicit, verified isolation of risk. Its only deductions are the same Dual Governance caveat applied honestly everywhere in this project (a real, thoughtful design that hasn't yet faced genuine adversarial pressure), and a Supply Chain Risk finding reflecting that Lido's real web/app bounty coverage, while more than most protocols disclose, still doesn't confirm the specific release-process safeguards this check requires. 82.5/97 under the complete v2.3 check set, up from 78 under the original 20/10 audit/code split, down from an intermediate 85.0 before Supply Chain Risk and Audit/Bounty Scope Coverage were added to the methodology.

Lido EarnETH (Yield Aggregator (Meta-Vault))

Universal Core (0–97)

No EarnETH-specific audit identified separately from Lido's broader audit history; the vault relies on the security of its underlying allocated protocols (Aave, Morpho, Pendle, Gearbox, Maple) rather than its own dedicated review. Operates as a meta-vault, dynamically allocating across sub-strategies (formerly GGV and stSTRATEGY) rather than a single fixed strategy.

Component	Score
Foundation (max 45)	20.0
Active (max 55)	30
Gross Score	50.0

Yield Aggregator — Category Penalty

Pattern	Finding	Deduction
P1 — Deprecated Strategy Retirement	NOT PRESENT (legacy vaults GGV, DVV, stSTRATEGY were migrated to withdrawal-only mode in an orderly relaunch, not left live and unaddressed — the opposite of the Yearn governance-stall failure mode)	0
P2 — Donation-Manipulable Share Price	CANNOT DETERMINE (share price / accounting mechanism for earnETH not independently verified from available sources)	0 (disclosed unverified)

Category total: **0 / -15**

Universal Checks

Check	Finding	Deduction
Inherited Risk	EXACT MATCH — EarnETH held a leveraged rsETH position on Aave (~9% of vault TVL, ~\$21.6M) directly exposed to the KelpDAO bridge exploit. This is the same dependency chain validated for Aave itself, and is a confirmed, realized exposure (not merely a theoretical one) — deposits and withdrawals were paused, and the vault tapped a real, pre-committed \$3M first-loss buffer (part of a \$5M DAO allocation approved in advance of the incident). Scored at full ceiling given direct, confirmed, realized exposure.	-5

Check	Finding	Deduction
Concentrated Control Risk	SIMILAR MATCH at reduced weight — EarnETH is managed by its own vault curators, who froze deposits/withdrawals independently during the incident, and its first-loss buffer is a distinct, pre-committed DAO allocation rather than an exercise of Dual Governance's core staking authority. No evidence Dual Governance's rage-quit mechanism has direct authority over curator-level vault decisions. Scored at half the weight applied to Core Staking.	-1.25
Supply Chain Risk	SIMILAR MATCH — same broader Lido bounty coverage exists but does not confirm the specific proactive release-process safeguards this check requires; no EarnETH-specific bounty or coverage confirmation found beyond the general Lido program.	-2.5
Audit/Bounty Scope Coverage	CANNOT DETERMINE — no EarnETH-specific bounty scope documentation found independent from the general Lido program; consistent with this product's broader documentation gaps already noted (Pattern 2 above).	0 (disclosed unverified)
FINAL SCORE		41.25 / 97

EarnETH is Lido's lowest-scoring product, for a specific and traceable reason: it carries the full, confirmed weight of the KelpDAO exposure (the same root incident validated at Aave), on top of a thinner audit foundation than core staking and an unverified share-price mechanism. The pre-committed \$3M first-loss buffer and curators' fast, independent freeze response are real positives, but do not offset a realized, dollar-quantified exposure. Recalibrated under the corrected 18/12 Audit/Code split; the lack of a dedicated audit weighs more heavily here than for Lido's core product, since EarnETH's own wrapper logic — not just the underlying allocated protocols — has not been independently reviewed.

Lido EarnUSD (Stablecoin Yield Vault)

Universal Core (0–97)

Launched March 2026; relies on third-party infrastructure provided by Mellow (a named, disclosed curator), with one active subvault as of this assessment. No EarnUSD-specific audit identified separately. The newest product in the Lido ecosystem, with the shortest track record of any Lido product scored in this project. Recalibrated from an earlier draft of this score, which scored thin track record as if it were a confirmed weakness rather than its own, distinct category of genuine uncertainty — see methodology note.

Component	Score
Foundation (max 45)	18.0
Active (max 55)	33
Gross Score	51.0

Stablecoin — Category Penalty

Pattern	Finding	Deduction
P1 — Mint Authority Control	NOT APPLICABLE (EarnUSD is a yield vault accepting deposits of existing stablecoins (USDC/USDT), not a stablecoin issuer with its own minting mechanism — this pattern does not apply to its design)	0
P2 — Collateral Liquidity Depth	CANNOT DETERMINE (vault liquidity depth and redemption capacity under stress not independently verified; 24-hour deposit waiting period disclosed but withdrawal mechanics under stress are not)	0 (disclosed unverified)
P3 (WATCH-ITEM) — Off-Chain Operational Dependency	SIMILAR MATCH (vault relies on Mellow, a named third-party curator, for subvault strategy; users explicitly assume risk of Mellow's infrastructure per Lido's own disclosed terms)	-0.75 → -1

Category total: -1 / -13.5 core

Universal Checks

Check	Finding	Deduction
Inherited Risk	None — EarnUSD was explicitly and directly confirmed to have no rsETH exposure and continued operating normally throughout the KelpDAO incident, unlike EarnETH.	0
Concentrated Control Risk	SIMILAR MATCH at reduced weight — same reasoning as EarnETH: no evidence Dual Governance's core authority extends to this curator-managed vault's specific decisions. Scored at half the weight applied to Core Staking.	-1.25
Supply Chain Risk	SIMILAR MATCH — same broader Lido bounty coverage exists but does not confirm proactive release-process safeguards specific to this newly launched product; no EarnUSD-specific bounty confirmation found.	-2.5
Audit/Bounty Scope Coverage	CANNOT DETERMINE — EarnUSD launched March 2026 and relies on Mellow's own infrastructure; no independent bounty scope documentation found specific to this product or its curator's contracts.	0 (disclosed unverified)
FINAL SCORE		46.25 / 97

EarnUSD is a genuinely new product with no disclosed weakness against it — its score reflects honest uncertainty from thin track record, not a confirmed problem. It depends on a named third-party curator (Mellow) whose own risk profile has not been independently assessed in this project, and it launched too recently to have a meaningful incident history either way. Its one verified positive is concrete: zero exposure to the KelpDAO incident, confirmed directly by Lido. Recalibrated under the corrected 18/12 Audit/Code split; this score sits below protocols with a known, bounded weakness and below protocols with a proven clean record, reflecting genuine uncertainty rather than either of those two more legible categories.